Capítulo 1

Threat Hunting na Prática: da Hipótese à Detecção, com Estudos de Caso no Hikari

Sidnei Barbieri, Ágney Lopes Roth Ferraz e Lourenço Alves Pereira Júnior (ITA)

Abstract

Threat hunting is the proactive search for adversary activity that automated detection missed. It starts from a hypothesis about how an attacker would behave, not from an alert, and may produce a detection candidate that needs validation against local data. This chapter teaches that cycle through practice. It organizes the concepts a hunter needs (hunting maturity, the PEAK and TaHiTI process models, MITRE ATT&CK, the Pyramid of Pain, and normalized telemetry in the Elastic Common Schema), and then runs three complete case studies over a reproducible scenario of a fictitious telecommunications operator: a sequence of VPN password attempts followed by a session and a new local administrator; a command-and-control beacon masquerading as a legitimate updater, followed by substantial outbound traffic; and Active Directory group enumeration followed by service-based lateral movement and mass file renaming in a ransomware simulation. Each case contains a deliberate decoy, a legitimate routine that makes the naive query return the wrong answer, so that the reader learns to refine hypotheses rather than sort tables. Every answer in the chapter is recomputed by code over the full event set, and the scenario is distributed as a challenge package for the Hikari gamified hunting platform, so that the case studies can be played as a competition.

Resumo

Threat hunting é a busca proativa por atividade adversária que a detecção automática não encontrou. Ele parte de uma hipótese sobre como um atacante se comportaria, e não de um alerta, e pode produzir uma detecção candidata, ainda sujeita à validação no ambiente. Este capítulo ensina esse ciclo pela prática. Organiza os conceitos de que o caçador precisa (maturidade de caça, os modelos de processo PEAK e TaHiTI, o MITRE ATT&CK, a Pirâmide da Dor e a telemetria normalizada no Elastic Common

Schema) e percorre três estudos de caso completos sobre um cenário reprodutível de uma operadora de telecomunicações fictícia: tentativas de senha na VPN seguidas de uma sessão e da criação de um administrador local; um canal de comando e controle disfarçado de atualizador legítimo, seguido de um volume elevado de tráfego de saída; e a enumeração de grupos do Active Directory seguida de movimento lateral por serviço remoto e renomeações em massa numa simulação de ransomware. Cada caso contém uma isca deliberada, uma rotina legítima que faz a consulta ingênua devolver a resposta errada, para que o leitor aprenda a refinar hipóteses em vez de ordenar tabelas. Toda resposta do capítulo é recalculada por código sobre o conjunto inteiro de eventos, e o cenário é distribuído como pacote de desafios para a plataforma de caça gamificada Hikari, para que os estudos de caso possam ser jogados como competição.

1.1. Introdução

Uma regra de detecção reconhece padrões definidos antes de observar o próximo evento. Ela pode alertar sobre uma sequência de falhas de autenticação e deixar passar a mesma atividade distribuída entre muitas contas. Pode também destacar um fluxo grande e ignorar um volume semelhante dividido em fluxos pequenos. A pergunta da caça a ameaças é concreta: que comportamento relevante a telemetria registra, mas as detecções existentes não procuram?

Threat hunting, ou caça a ameaças, é a investigação orientada por hipóteses sobre atividade adversária. O caçador explicita o comportamento esperado, verifica se há dados capazes de observá-lo, procura evidências e registra o que a busca permite concluir. Uma busca sem resultado só restringe a hipótese nas fontes, no período e nas condições examinadas; não prova ausência de ataque. Quando encontra um padrão útil, a equipe pode transformá-lo numa detecção candidata, sujeita a teste de falsos positivos e manutenção [Sqr16, B+23].

1.1.1. Por que ensinar caça pela prática

A caça é uma competência de raciocínio sobre dados, e não de memorização de ferramentas. A mesma pergunta "quem tentou muitas contas e conseguiu entrar?" pode ser feita em Kibana, Splunk ou Sentinel; o que distingue o caçador é saber que a pergunta certa não é "quem mais falhou". Esse tipo de discernimento se aprende enfrentando dados em que a pergunta ingênua leva ao lugar errado. Por isso este capítulo não apresenta a caça como lista de consultas, e sim como sequência de hipóteses postas à prova sobre um ambiente com ruído realista, no qual rotinas legítimas imitam o comportamento do ataque.

Competições do tipo *Capture the Flag* (CTF) são um formato consolidado para esse aprendizado [ŠČVB21], mas as tarefas típicas que esses levantamentos descrevem, como explorar sites, quebrar senhas e invadir redes desprotegidas, são ofensivas. A plataforma Hikari [BBC+25] inverte a perspectiva: o competidor investiga eventos num SIEM real, responde perguntas cuja resposta está na telemetria, e a investigação cresce em fases à medida que as equipes avançam. A plataforma conduziu o CTF do exercício setorial de cibersegurança das operadoras de telecomunicações brasileiras promovido pela ANATEL (RESEG) em 2025 e em 2026; a edição de 2026 reuniu 13 equipes e 76 competidores, que resolveram 125 desafios e fizeram 54.698 consultas ao SIEM numa janela de quatro

horas.

1.1.2. O que o minicurso entrega

O capítulo acompanha um minicurso de três horas, organizado em torno de três estudos de caso completos sobre um mesmo cenário, a operadora fictícia Aurora Telecom:

1. **Da força bruta ao privilégio** (Seção 1.5): uma origem externa tenta senhas de muitas contas e estabelece uma sessão na VPN, usa a sessão para um acesso remoto a um servidor financeiro e cria ali um novo administrador.
2. **O canal que respira** (Seção 1.6): após a abertura de um documento habilitado para macros, inicia-se um processo com nome de atualizador legítimo, que consulta um domínio a cada cinco minutos e, na noite seguinte, envia cerca de 2.293 megabytes a um destino externo em fluxos de tamanho semelhante.
3. **Do mapa do diretório ao impacto** (Seção 1.7): uma conta administrativa enumera 47 grupos do Active Directory, instala um serviço remoto nos servidores de arquivos, apaga as cópias de sombra e renomeia 3.420 arquivos.

Em cada caso, uma rotina legítima torna enganosa a primeira agregação. O leitor compara o resultado ingênuo com a hipótese, identifica a variável que falta e segue os pivôs até uma conclusão delimitada pelos eventos. As respostas e as iscas foram recalculadas sobre os 49.277 eventos do cenário sintético (Seção 1.4); o objetivo desse controle é permitir que o exercício ensine o raciocínio sem depender da autoridade do gabarito.

O cenário é inteiramente fictício e foi construído para este minicurso. Nenhum dado de competição real é usado, o que permite oferecer o curso antes de uma prova sem entregar respostas a quem vai competir.

1.1.3. Organização do capítulo

A Seção 1.2 apresenta os conceitos e modelos de processo da caça e os fundamentos de telemetria e de consulta de que os estudos de caso dependem. A Seção 1.3 situa a caça na literatura e na prática de SOCs e discute o papel de competições no ensino de defesa. A Seção 1.4 apresenta os eventos sintéticos e o modo de acompanhar os casos. As Seções 1.5 a 1.7 trazem os estudos de caso, cada um com hipótese, fontes de dados, investigação passo a passo, a isca, a detecção derivada e exercícios. A Seção 1.8 discute como transformar caçadas em detecções, os limites do material e as conclusões.

1.2. Conceitos e Modelos de Caça

Esta seção reúne o vocabulário usado no restante do capítulo: o que distingue a caça da detecção e da resposta a incidentes, como a caça é organizada em processo, como se escolhe o que caçar e sobre que dados se caça.

1.2.1. Detecção, resposta e caça

Os três termos convivem no mesmo SOC e são frequentemente confundidos. A **detecção** é reativa e automatizada: regras e modelos examinam a telemetria continuamente e geram alertas. A **resposta a incidentes** começa quando algo já foi identificado como incidente

e cuida de contê-lo, erradicá-lo e recuperar o ambiente; o NIST SP 800-61 Rev. 3 a organiza em torno das funções do CSF 2.0 [NRSS25]. A **caça** ocupa o espaço entre as duas: é humana, orientada por hipótese e não por alerta, e procura o que a detecção ainda não sabe reconhecer [LB16].

A distinção importa porque muda o critério de sucesso. Um analista de triagem é bem-sucedido quando fecha alertas com rapidez e acerto. Um caçador é bem-sucedido quando reduz a incerteza sobre o ambiente: delimitar onde e quando uma técnica não foi observada, com a cobertura disponível, também é resultado.

1.2.2. Modelos de intrusão e o lugar da caça

Dois modelos anteriores ao ATT&CK ainda organizam o raciocínio de quem caça. A **cadeia de intrusão** (*kill chain*) de Hutchins, Cloppert e Amin descreve o ataque como uma sequência de fases pelas quais o adversário precisa passar com sucesso antes de atingir o objetivo; a consequência defensiva, nas palavras dos autores, é que uma única mitigação interrompe a cadeia [HCA11]. Para a caça, isso significa que basta encontrar uma fase: o Caso 1 encontra o acesso inicial, o Caso 2 o comando e controle, o Caso 3 o reconhecimento que antecede o impacto. O **modelo diamante** de Caltagirone, Pendergast e Betz descreve cada evento de intrusão por quatro elementos, o adversário, a capacidade, a infraestrutura e a vítima [CPB13, ASSO25], e é útil como roteiro de pivô: de uma infraestrutura (um domínio) chega-se a uma vítima (a estação que o consulta) e a uma capacidade (o processo que o gera).

No nível organizacional, o NIST CSF 2.0 distribui a gestão de risco cibernético em seis funções, Governar, Identificar, Proteger, Detectar, Responder e Recuperar [Nat24], e a revisão 3 do SP 800-61 passou a tratar a resposta a incidentes como um perfil desse arcabouço [NRSS25]. A caça pertence à função Detectar, mas depende das outras: sem a telemetria que a gestão de logs descrita no SP 800-92 prevê [KS06], não há o que caçar, e sem a função Responder, uma caçada bem-sucedida não se converte em contenção. O D3FEND, da MITRE, complementa o ATT&CK do lado do defensor, organizando contramedidas num grafo de conhecimento [The24].

1.2.3. Maturidade de caça

O Hunting Maturity Model, proposto pela Sqrrl [Sqr16], descreve cinco níveis de capacidade de uma organização, de HM0 a HM4. No nível inicial, a organização depende quase só de alertas automáticos e coleta pouca telemetria. Nos níveis intermediários, ela passa a coletar dados suficientes, a seguir procedimentos de caça escritos por outros e, depois, a criar os próprios procedimentos. No nível mais alto, os procedimentos bem-sucedidos são sistematicamente automatizados, e a caça alimenta a detecção. O modelo é útil menos como régua e mais como lembrete de dois pré-requisitos: sem telemetria não há caça, e um padrão recorrente que não é convertido em detecção exige nova investigação manual.

1.2.4. Modelos de processo: PEAK e TaHiTI

Dois modelos de processo são referência na prática atual. O **PEAK** (*Prepare, Execute, Act with Knowledge*) [B+23] organiza cada caçada em três fases: preparar (escolher o tema, pesquisar a técnica, formular a hipótese, verificar se os dados existem), executar

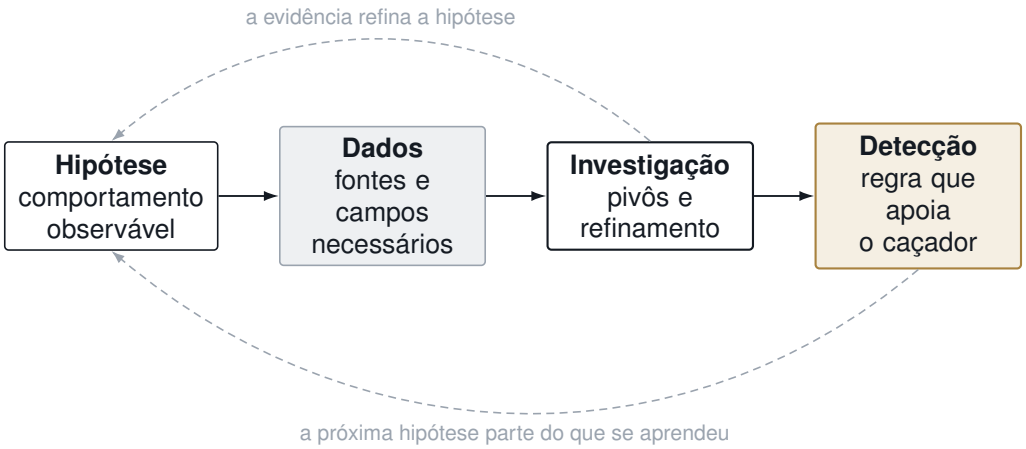


Figura 1.1. O ciclo de caça seguido nos estudos de caso, núcleo comum aos modelos PEAK e TaHiTI.

(coletar, analisar, refinar a hipótese) e agir (documentar, criar detecções, comunicar). O PEAK distingue três tipos de caçada: as *orientadas por hipótese*, como as deste capítulo; as de *linha de base*, que descrevem o normal para achar o anômalo; e as *auxiliadas por modelos*, em que algoritmos apontam candidatos para o humano examinar.

O **TaHiTI** (*Targeted Hunting integrating Threat Intelligence*), publicado pelo setor financeiro holandês [Bet18], dá mais peso à inteligência de ameaças como fonte de gatilhos e divide o processo em iniciar, caçar e finalizar, com um repositório de hipóteses (*backlog*) que é priorizado continuamente. Os dois modelos concordam no essencial, e os estudos de caso seguem esse núcleo comum:

1. uma **hipótese testável**, escrita como comportamento observável na telemetria;
2. as **fontes de dados** capazes de confirmá-la ou refutá-la;
3. a **investigação**, em que a hipótese é refinada à medida que a evidência aparece;
4. a **conclusão documentada** e, quando justificável, uma **detecção candidata**.

1.2.5. O que caçar: ATT&CK e a Pirâmide da Dor

Hipóteses precisam de vocabulário comum. O **MITRE ATT&CK** [SAM+18] cataloga táticas (o objetivo do adversário naquele momento, como Acesso Inicial ou Movimentação Lateral) e técnicas (como ele o alcança, como T1110 Brute Force ou T1021.001 Remote Desktop Protocol), com procedimentos observados, fontes de dados e mitigações. Ancorar a hipótese numa técnica permite reaproveitar o que a comunidade já sabe sobre como ela aparece na telemetria, e permite medir cobertura: quais técnicas relevantes para o ambiente já têm caçada ou detecção. A cobertura, porém, é uma medida imperfeita. Ao comparar produtos de detecção de endpoint, Virkud et al. mostram que muitas técnicas são difíceis, quando não impossíveis, de escrever como regra de detecção eficaz, e que produtos diferentes anotam o mesmo comportamento detectado com técnicas diferentes [VIR+24]; a revisão de Al-Sada et al., sobre mais de cinquenta trabalhos que usam o arcabouço, reúne as questões ainda em aberto no seu uso [ASSO25].

A **Pirâmide da Dor** [Bia13] ordena os indicadores pelo custo que impõem ao adversário quando são bloqueados: hashes e endereços IP estão na base, fáceis de trocar; domínios e artefatos de rede e de host no meio; ferramentas e, no topo, táticas, técnicas e procedimentos (TTPs), caros de mudar. A consequência para a caça é direta: hipóteses sobre *comportamento* sobrevivem à troca de infraestrutura do adversário, hipóteses sobre *indicadores* não. Entrevistas com praticantes que analisam ameaças persistentes apontam a mesma prioridade: entender táticas, técnicas, procedimentos e motivações vem antes de saber quem está por trás do ataque [SMB+25]. A pirâmide ordena, contudo, o custo imposto ao adversário, e não a utilidade para atribuir autoria: no ransomware, indicadores de alto nível carecem da especificidade necessária para atribuição, e os praticantes recorrem aos de baixo nível, mais voláteis [vdHKG+25]. Os três estudos de caso deste capítulo partem de comportamento (muitas contas por origem, regularidade de consultas, amplitude de enumeração) e só chegam a indicadores (um IP, um domínio, um hash) como consequência.

1.2.6. Telemetria normalizada e consultas

Caçar exige telemetria com campos previsíveis. O **Elastic Common Schema** (ECS) [Ela24] define nomes comuns para dados de fontes diferentes: `source.ip` e `destination.ip` para os lados de uma conexão, `user.name` para a conta, `host.name` para a máquina que registrou o evento, `event.action` e `event.outcome` para o que aconteceu e com que resultado, `process.executable` e `process.parent.name` para processos. Com os campos normalizados, a mesma pergunta atravessa VPN, firewall e EDR sem tradução. Todos os eventos do cenário Aurora seguem o ECS, e o conjunto de origem de cada evento fica em `event.dataset`.

No Kibana, a investigação combina duas ferramentas. A **Kibana Query Language** (KQL) filtra eventos: `event.dataset:"vpn"and event.outcome:"failure"` seleciona as falhas de autenticação da VPN; operadores `and`, `or` e `not`, curingas como `process.executable:*AppData*` e intervalos de endereços como `not destination.ip:"10.0.0.0/8"` cobrem a maior parte das necessidades. A KQL não agrega: contagens, contagens únicas, somas e ordenações são feitas nas visualizações (o painel de valores de um campo no Discover e as tabelas do Lens). Por isso, ao longo do capítulo, cada passo é descrito como um filtro KQL seguido da agregação que responde à pergunta, na notação

```
<filtro KQL>  →  <agregação feita no Lens ou no painel do campo>
```

1.2.7. Referência rápida: o que perguntar, e como

O caçador passa o dia traduzindo hipóteses em duas partes: um filtro, que reduz o conjunto, e uma agregação, que responde à pergunta. A Tabela 1.1 reúne os padrões que os três estudos de caso usam. Vale a pena lê-la uma vez antes dos casos e voltar a ela durante a prática.

A agregação deve medir o comportamento da hipótese. No Caso 1, contar contas distintas por origem distingue a tentativa distribuída da repetição numa conta. No Caso 2, a série temporal separa a consulta periódica de um total alto acumulado durante dias; o sentido do fluxo distingue bytes enviados de bytes recebidos. No Caso 3, grupos distintos

Tabela 1.1. Padrões de filtro e agregação usados nos estudos de caso.

A pergunta	O filtro (KQL)	A agregação
Quem falha mais? (contagem bruta, quase sempre a isca)	`event.dataset:"vpn"and event.outcome:"failure"`	contagem por `source.ip`
Quem tenta muitas *contas diferentes*?	o mesmo filtro	contagem *única* de `user.name` por `source.ip`
Quem conversa com um nome que só uma máquina conhece?	`event.dataset:"dns"`	contagem e contagem única de `host.name` por `dns.question.name`
Com que regularidade?	filtro pelo nome suspeito	diferenças entre `@timestamp` consecutivos (mediana e extremos)
Quanto saiu para fora?	`event.dataset: "firewall"and not destination.ip: 10.0.0.0/8`	soma de `source.bytes` por `destination.ip`
Quem mapeia o diretório?	`event.dataset:"auth"and event.code:"4799"`	contagem única de `group.name` por `user.name`
De onde partiu? (pivô de endereço)	`event.dataset:"auth"and host.ip: "10.40.0.140"and winlog.logon.type:"2"`	primeiras linhas por `@timestamp`
O que é novo neste servidor?	`event.dataset: "fileserver"`	contagem por `file.extension` e por `process.name`

por conta medem amplitude de enumeração. Nenhuma dessas medidas, isolada, identifica um ataque.

1.2.8. Pivôs

Um **pivô** é a passagem de um valor encontrado numa fonte para a busca desse valor em outra, ou em outro campo da mesma fonte. O endereço interno que a VPN atribuiu ao atacante vira filtro nos eventos de autenticação do Windows; o nome da estação que consulta um domínio suspeito vira filtro no EDR; o endereço de origem de uma enumeração vira filtro nos logons interativos, que dizem o nome da máquina. Pivotar é o que transforma um indício isolado numa linha do tempo, e cada estudo de caso deste capítulo é, no fundo, uma sequência de pivôs justificada por uma hipótese.

1.3. Caça a Ameaças na Literatura e na Prática

Esta seção reúne resultados publicados sobre seis questões: como organizar uma caçada, como os analistas trabalham, que limites encontram nos centros de operações de segurança, de onde vêm as hipóteses, o que a automação consegue investigar e como transformar uma descoberta em detecção. A Tabela 1.2 resume a contribuição de cada linha e a decisão que permanece com o analista.

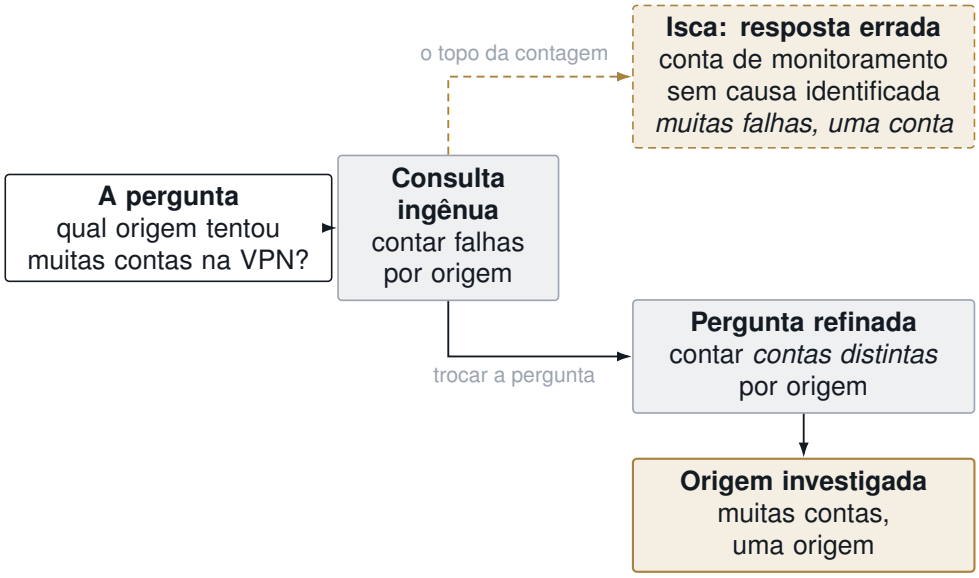


Figura 1.2. A anatomia de uma isca, no formato dos três estudos de caso. A consulta mais óbvia tem uma resposta, e ela é uma rotina legítima. A caçada só avança quando a pergunta muda de *quanto* para *quantos diferentes*.

1.3.1. Da busca manual ao processo

Os primeiros textos a tratar a caça como disciplina própria vieram da indústria, e não da academia. O documento da Sqrrl [Sqr16] introduziu o modelo de maturidade e o ciclo de caça, e o texto de Lee e Bianco para o SANS [LB16] tratou de como gerar hipóteses, a etapa que decide se a busca terá um alvo testável. Na década seguinte, o foco passou do *que* é caça para o *como* torná-la repetível. O PEAK [B+23] formaliza tipos de caçada e artefatos de saída, e o TaHiTI [Bet18] integra a caça ao ciclo de inteligência de ameaças de uma organização. O ponto em comum é a documentação: uma caçada que não deixa hipótese, consultas e conclusão escritas não pode ser repetida, revisada nem ensinada.

1.3.2. O que se mediu sobre quem caça

A pesquisa empírica sobre a caça é recente, e o que ela encontrou justifica um curso prático. Badva et al. entrevistaram 22 caçadores experientes e identificaram três abordagens, combinadas conforme a necessidade: por hipótese ou caso de uso, por inteligência e ao acaso, sem plano prévio e guiada por intuição. Os entrevistados relataram dificuldade recorrente em formular hipóteses diante de táticas novas, e o estudo conclui que a atividade exige conhecimento tácito, o que torna o treinamento essencial para iniciantes [BRPR24]. Maxam e Davis entrevistaram caçadores que atendem órgãos federais dos Estados Unidos, onde a caça é obrigatória, e relatam que a maioria das equipes opera sem um processo definido [MD24]. O levantamento de Nour et al. situa a caça em redes corporativas diante de ameaças persistentes, que ficam ocultas por longos períodos fora do alcance dos sistemas de detecção [NPD23].

A mesma pesquisa mostra o que o caçador prioriza. Em entrevistas com praticantes que analisam ameaças persistentes avançadas, Saha et al. observaram que entender táticas, técnicas, procedimentos e motivações do adversário vem antes de identificar quem

está por trás do ataque [SMB+25]. É a mesma ordem que a Pirâmide da Dor recomenda (Seção 1.2), e é a ordem dos três estudos de caso deste capítulo.

1.3.3. O que se mediu sobre o SOC

A caça acontece dentro de uma operação saturada. Numa medição de quatro anos de alertas de rede num SOC em operação, Yang et al. observaram de 24 mil a 134 mil alertas por dia, dos quais apenas 0,01% estavam associados a ataques verdadeiros, e investigações pós-ataque de 53 dias em média [YCW+24]. Revisões sobre fadiga e priorização de alertas descrevem analistas sobrecarregados por esse volume [TCNP25, JCNP25].

Estudos com analistas explicam por que o volume pesa tanto. Kokulu et al. entrevistaram analistas e gestores de SOC e encontraram divergências entre eles sobretudo quanto à velocidade de resposta e à automação, às métricas de avaliação e às funcionalidades das ferramentas [KSB+19]. AlAhmadi, Axon e Martinovic ouviram praticantes que confirmam taxas altas de falsos positivos, mas atribuem a maior parte deles a disparos benignos, alarmes corretos explicados por comportamento legítimo do ambiente, e propõem cinco propriedades que um alarme precisa ter para ser validado com rapidez [AAM22]. Uma etnografia de 34 meses num SOC acompanhou o monitoramento migrando do perímetro para o endpoint, com efeitos sobre a privacidade dos usuários e o esgotamento dos analistas [JBHFB23]. Os disparos benignos também custam em produção: seis anos de relatos de falsos positivos recebidos por um grande fornecedor de segurança mostram que as listas de domínios populares não bastam para evitá-los em detectores de domínios maliciosos, e que a pesquisa se concentrou nos indicadores de comprometimento e deu pouca atenção aos indicadores de benignidade [LSC+26].

O aprendizado de um incidente também pode se perder depois da detecção. Entrevistas com 69 especialistas mostram advogados contratados pelas seguradoras orientando investigadores a não registrar por escrito os passos de remediação [WBWS23]. A análise de 1.217 *playbooks* de resposta, complementada por questionário com 147 participantes e entrevistas, encontrou ambiguidades intrínsecas na forma como praticantes e organizações definem esses documentos [SEC+24]. A lição para a caça é prática: documentar a hipótese, as consultas e a conclusão é parte do trabalho, e não burocracia posterior.

1.3.4. A inteligência de ameaças como fonte de hipóteses

A inteligência de ameaças é a fonte mais óbvia de hipóteses, e a pesquisa mostra por que ela precisa ser conferida antes de virar caçada. Sun et al. observam que a maioria das organizações ainda usa a inteligência em casos básicos, como *feeds* de dados integrados a firewalls, sistemas de prevenção de intrusão e SIEMs, sem aproveitar o que ela poderia informar [SDJ+23]. Para a resposta a incidentes, Schlette et al. propõem 18 conceitos centrais e analisam seis formatos de intercâmbio, apontando deficiências nesses formatos [SCP21]. E o conteúdo compartilhado nem sempre é confiável. Jin et al. coletaram cerca de seis milhões de objetos STIX de dez fontes públicas: o volume ainda é baixo para cobrir todas as ameaças, assinaturas de malware e URLs somam mais de 90% do que se compartilha, e 19% dos registros de ator de ameaça continham informação incorreta [JKL+24].

A pesquisa tenta aproximar esse conhecimento da telemetria. O Extractor extrai

comportamentos de ataque do texto de relatórios e os representa como grafos de proveniência [SGV21], o POIROT modela a caça como o alinhamento entre um grafo derivado de inteligência e o grafo de auditoria do kernel [MEGV19], e o KnowHow aplica diretamente o conhecimento de relatórios escritos em linguagem natural aos eventos de baixo nível [MLG+26]. Para o caçador, a consequência é direta: uma hipótese vinda de inteligência é um ponto de partida, e o que a confirma ou descarta é a telemetria do próprio ambiente.

1.3.5. Investigação automatizada sobre logs de auditoria

A linha de pesquisa mais numerosa nas conferências de segurança trata de automatizar a investigação que o caçador faz à mão, representando os logs de auditoria como grafos de proveniência, que encadeiam os eventos numa história causal da execução do sistema [ICG+23]. O HOLMES correlaciona fluxos de informação suspeitos para produzir um sinal de campanha e um grafo que resume as ações do atacante em tempo real [MGE+19]. O NoDoze combate a fadiga de alertas pontuando cada alerta pelo contexto histórico do grafo; num conjunto de 364 alertas, estimou redução de 84% dos falsos alarmes [HGL+19]. O Unicorn resume execuções longas com esboços de grafo para alcançar ataques lentos [HPB+20], o OmegaLog enxerta eventos de aplicação no grafo do sistema para reduzir a lacuna entre camadas [HNDB20], e a análise tática de proveniência raciocina sobre dependências entre alertas de EDR em vez de eventos de baixo nível [HBM20].

Os trabalhos seguintes atacam o tamanho do que se entrega ao analista. Grafos de causalidade costumam passar de cem mil arestas, e o DepImpact e o DEPCOMM os reduzem a subgrafos e comunidades inspecionáveis [FGL+22, XFL+22]. O ATLAS e o AirTag reconstroem a história do ataque, o primeiro com modelos de sequência e o segundo aprendendo sobre o texto dos logs sem rotulação [ANM+21, DZNM23]. O WATSON agrega a semântica dos eventos para reduzir a dependência de regras escritas por especialistas [ZCC+21], e o SteinerLog correlaciona alertas de várias fontes para reconstruir campanhas [BH22]. Detectores mais recentes buscam operação em linha e escala [JXN+24, YXX+23, LDX+24, ZGY+25]. O Kairos identifica quatro dimensões que orientam esses sistemas, o alcance entre aplicações, a detecção de ataques desconhecidos, a pontualidade e a reconstrução do ataque, e é apresentado pelos autores como o primeiro a atender às quatro ao mesmo tempo [CLL+24].

O movimento lateral, tema do primeiro e do terceiro casos, tem linha própria. O Hopper constrói o grafo de logons entre máquinas internas e infere o caminho e o usuário causal de cada sequência; em 15 meses de dados corporativos, com mais de 780 milhões de logons, detectou 94,5% de mais de 300 cenários realistas [HDA+21]. O Euler trata os logs da rede como grafos temporais e reformula a detecção como previsão de arestas anômalas [KH22], e o Jbeil aplica aprendizado indutivo sobre grafos temporais para lidar com redes que mudam durante a coleta [KKZ+24].

1.3.6. Por que a automação ainda não substitui o caçador

A passagem para a operação é menos direta do que os resultados publicados sugerem, e três trabalhos medem por quê. Bilot et al. implementaram oito sistemas de detecção por

proveniência num arcabouço comum e identificaram nove deficiências que dificultam o uso prático [BJL+25]. Dong et al. ouviram especialistas da indústria, que consideram esses sistemas mais eficazes que as ferramentas convencionais de detecção em endpoint, mas se preocupam com o custo de operá-los, e apontaram três lacunas entre academia e indústria: 19 de 20 sistemas levantados ignoram o custo de coletar os dados no próprio cliente, os projetos desequilibram o custo de triar um alarme e o de interpretá-lo, e o consumo de memória no servidor é excessivo [DLJ+23]. Jiang et al. atribuem a relutância da indústria à baixa qualidade da atribuição, isto é, ao esforço que o analista ainda precisa gastar para entender e descartar o que o detector entrega [JBEM+25]. Mesmo a alternativa mais leve tem o seu custo: o CAPTAIN mostra que detectores por regras, leves e explicáveis, sofrem com falsos alarmes quando não são ajustados ao ambiente [WSL+25].

O adversário também se adapta. Ataques de mimetismo evadiram os três sistemas de detecção por grafo de proveniência avaliados sem alterar o comportamento do ataque [GHWB23], e o ProvNinja gera ações que imitam o perfil estatístico de programas do sistema [MWW+23]. O ShadowMove mostra que o movimento lateral pode dispensar os sinais que os detectores procuram, reaproveitando conexões já estabelecidas em vez de abrir conexões novas ou fazer novas autenticações [NWA+20]. As duas frentes apontam para o mesmo lugar: quanto mais automática a detecção, mais valor tem quem formula uma hipótese que ela ainda não conhece.

1.3.7. Da caçada à engenharia de detecção

A passagem da caçada bem-sucedida para a detecção automática ganhou nome e ferramentas próprias. Formatos abertos como o Sigma [Sig24] descrevem a lógica de uma detecção independentemente do SIEM, e ela depois é convertida para a linguagem de cada produto. Isso torna a detecção revisável e compartilhável, e dá à caça um destino concreto: cada estudo de caso deste capítulo termina com a regra que a caçada justificou, escrita de forma que outra equipe possa discordar dela com argumentos.

A qualidade da regra é objeto de pesquisa. Num SOC comercial gerenciado, Teuwen et al. derivaram seis princípios de projeto para regras de detecção de rede, consolidados em entrevistas com quem as escreve, e mediram que várias escolhas de projeto mudam significativamente a carga desnecessária que a regra impõe aos analistas [TMZA25]. A especificidade, porém, tem custo: ao analisar regras de SIEM amplamente usadas, Uetz et al. mostraram que adversários conseguem evadir quase metade delas com facilidade, e propuseram comparar os eventos às regras e ao comportamento benigno conhecido para encontrar as evasões [UHH+24].

O ATT&CK [SAM+18] costuma fechar o ciclo como mapa de cobertura, e a pesquisa recomenda cautela com esse uso. Virkud et al. compararam as regras de três produtos comerciais de detecção em endpoint: a cobertura das técnicas fica entre 48% e 55%, cai para 25% a 26% quando se descartam as regras de risco baixo e médio, e 53 técnicas, 27,7% do total, não são implementadas por nenhum dos produtos. Os autores concluem que muitas técnicas são difíceis, quando não impossíveis, de escrever como regra eficaz, que produtos diferentes anotam o mesmo comportamento detectado com técnicas diferentes, e que a cobertura pode não ser uma boa métrica de segurança [VIR+24]. A avaliação anual da MITRE sobre produtos de EDR, reanalisada por Shen et al., é outra fonte para

entender o que os produtos de fato detectam [SLB+24].

1.3.8. Aprender a defender

A formação de defensores enfrenta um problema de escala: a competência que se quer desenvolver, investigar telemetria real sob pressão, é difícil de praticar fora de um SOC em operação. Competições do tipo CTF são uma resposta difundida. Exercícios de CTF em sala de aula foram relatados como ferramenta de ensino de segurança [MP14]. Švábenský et al. analisaram 15.963 soluções escritas de desafios de CTF e as mapearam às diretrizes curriculares da área: predominam conhecimentos técnicos de criptografia e segurança de redes, e aspectos humanos, como engenharia social e conscientização, são negligenciados. As tarefas típicas que o estudo descreve, como explorar sites, quebrar senhas e invadir redes desprotegidas, são ofensivas [ŠČVB21]. A revisão de Švábenský, Vykopal e Čeleda sobre os artigos de educação em segurança do SIGCSE e do ITiCSE mapeia o que essa comunidade tem publicado [ŠVČ20].

Os exercícios defensivos existem, mas custam caro. Os *cyber ranges*, ambientes que emulam redes inteiras para exercício, foram sistematizados por Yamin, Katt e Gkioulos em cenários, funções, ferramentas e arquitetura [YKG20], e Vykopal et al. documentaram o ciclo de vida de exercícios defensivos complexos, do desenvolvimento e ensaio à execução, avaliação e repetição, com o esforço de preparação que ele exige dos organizadores [VVO+17].

O Hikari [BBC+25] oferece investigações defensivas sobre eventos indexados. Para este capítulo, a questão pedagógica é a validade da evidência: uma resposta declarada que não pode ser obtida dos eventos impede distinguir erro do aluno de erro do exercício. O cenário Aurora foi construído com rotinas benignas que competem com a hipótese de ataque, e suas respostas são recalculadas sobre todos os eventos. Esse controle garante consistência interna do exercício, não realismo estatístico de uma rede em operação (Seção 1.4).

Os três estudos de caso tocam problemas com literatura própria. A exfiltração do segundo caso é estudada tanto em revisões de detecção por aprendizado de máquina [SUBG22] quanto em detectores que estimam, em tempo real, o volume de informação enviado a cada domínio registrado pelo DNS [ONS24], e a ideia de medir o volume que sai por destino é a mesma que o caso aplica à mão sobre os registros de firewall. O ransomware do terceiro caso tornou-se um dos vetores de ataque mais comuns e lucrativos da última década [SHW+25], e as defesas contra ele foram revisadas conforme a plataforma atacada [OALU22].

1.3.9. O que este capítulo acrescenta

Este capítulo usa três investigações completas para mostrar onde uma contagem inicial falha e que observação permite avançar. Cada caso coloca uma rotina benigna diante da hipótese, registra o campo que sustenta o próximo pivô e termina com uma detecção candidata e seus limites. Os eventos sintéticos e as respostas verificadas permitem repetir as consultas; a transferência dos limiares para outra rede exige nova medição.

Tabela 1.2. Linhas de pesquisa próximas da caça, com trabalhos representativos e o que cada uma ainda deixa para o caçador.

Linha	Trabalhos	O que ainda depende do caçador
Prática e processo	[BRPR24, MD24, NPD23, SMB+25, B+23]	hipóteses dependem de conhecimento tácito; muitas equipes não têm processo definido
Operação do SOC	[YCW+24, AAM22, KSB+19, TCNP25, LSC+26]	separar ataque de disparo benigno no volume diário
Inteligência de ameaças	[SDJ+23, SCP21, JKL+24, SGV21, MLG+26]	conferir contra a telemetria uma inteligência que pode estar errada
Proveniência e investigação	[MGE+19, HGL+19, CLL+24, HDA+21, BJL+25, JBEM+25]	adoção limitada por custo operacional e qualidade da atribuição
Evasão	[GHWB23, MWW+23, UHH+24, NWA+20]	hipóteses de comportamento que o adversário não imita barato
Engenharia de detecção	[Sig24, TMZA25, VIR+24, SLB+24]	regras específicas, testadas contra o histórico, e cobertura lida com cautela

Tabela 1.3. Os conjuntos de eventos do cenário Aurora.

Conjunto	Eventos	O que registra
`dns`	22.159	consultas de nome feitas pelas estações
`firewall`	9.655	conexões permitidas, com bytes enviados (`source.bytes`) e recebidos (`destination.bytes`)
`fileserver`	7.340	modificações e renomeações de arquivos nos servidores de arquivos
`edr`	4.696	processos iniciados, serviços instalados e ações de proteção nos hosts
`vpn`	2.967	autenticações e sessões do concentrador de VPN
`auth`	2.460	logons, criação de contas e enumeração de grupos no Windows e no AD

1.4. Cenário e Evidência dos Estudos de Caso

1.4.1. Como ler a evidência

Os três estudos de caso usam eventos normalizados para responder a perguntas sobre comportamento. Em cada passo, um filtro seleciona eventos, uma agregação confronta a hipótese e um campo observado autoriza o próximo pivô. O cenário é fictício; por isso o leitor pode acompanhar todas as respostas e discutir também as explicações benignas sem expor uma operação real.

1.4.2. A Aurora Telecom

A Aurora Telecom é uma operadora fictícia com 120 colaboradores, cada um com uma estação de trabalho, cinco servidores de aplicação, dois controladores de domínio e dois servidores de arquivos. O cenário cobre três dias, de 9 a 11 de março de 2026, e reúne 49.277 eventos em seis conjuntos (Tabela 1.3).

O ruído não é aleatório: ele contém rotinas escolhidas por se parecerem com os

ataques. Uma conta chamada `monitor.vpn` falha na VPN a cada três minutos durante os três dias; os eventos não informam por quê. Todas as estações consultam o domínio de atualização da empresa de hora em hora. O servidor de gerenciamento envia fluxos de vários gigabytes a um destino interno toda madrugada, e as estações baixam atualizações de centenas de megabytes de um espelho externo. Uma ferramenta de inventário enumera os mesmos três grupos do diretório a cada dez minutos, e um agente de backup renomeia centenas de arquivos nos servidores de arquivos no mesmo horário. São essas rotinas que obrigam cada estudo de caso a refinar a hipótese.

1.4.3. Por que um cenário próprio, e não uma base pública

Existem bases públicas valiosas para pesquisa em detecção. A base do Los Alamos National Laboratory reúne 58 dias consecutivos de logs de cinco fontes da rede corporativa interna do laboratório, com atividade normal e uma campanha de *red team* [Ken15, KH22], e foi usada, por exemplo, na avaliação de detectores de movimento lateral [KH22]; os dados dos exercícios do programa Transparent Computing, da DARPA, são referência na avaliação de detectores por proveniência [DAR20, BJL+25]. Para ensinar caça elas têm dois limites. O primeiro é que a verdade de referência é parcial ou grosseira, o que torna difícil dizer ao aluno, com certeza, que a resposta dele está certa. O segundo é que elas não trazem iscas escolhidas: o ruído existe, mas não foi desenhado para que a consulta ingênua erre de modo instrutivo. O cenário Aurora troca realismo de escala por gabarito verificável e por iscas deliberadas, e declara essa troca nos limites da Seção 1.8.

1.4.4. Reprodutibilidade e conferência do gabarito

O cenário é produzido por um programa em Python, a partir de uma semente fixa, e a mesma semente gera byte a byte os mesmos eventos. Cada estudo de caso declara os eventos injetados, as perguntas e as respostas esperadas. A resposta declarada nunca é usada como prova: um conferidor calcula cada resposta sobre o conjunto inteiro de eventos, incluindo o ruído. Ele também executa a consulta ingênua de cada isca e exige que ela conduza a uma resposta diferente. Se houver empate no topo da agregação, o gabarito é rejeitado. Esse controle reduz erros no exercício; não demonstra que o cenário reproduz a distribuição de eventos de uma rede real.

1.4.5. Acompanhamento dos casos

As tabelas, consultas e linhas do tempo permitem acompanhar a solução sem computador. Os cadernos de prática refazem as agregações sobre os mesmos eventos para quem quiser variar filtros e testar explicações alternativas. A apresentação mostra os resultados necessários para discutir cada decisão em sala; as aulas narradas permitem retomar os três percursos depois.

1.4.6. Como cada estudo de caso está escrito

As três seções seguintes têm a mesma estrutura: o incidente em uma frase; a hipótese de partida e as técnicas do ATT&CK envolvidas; as fontes de dados; a investigação, em passos numerados, cada um com a pergunta, o filtro KQL, a agregação e o que ela revela; a isca e por que ela engana; a linha do tempo reconstruída; a detecção derivada; e exercícios. As respostas aparecem no texto porque este é um capítulo de ensino. Quem quiser jogar

antes de ler deve importar o pacote e resolver os desafios primeiro.

1.5. Estudo de Caso 1: Da Força Bruta ao Privilégio

O incidente. Na madrugada de 10 de março, uma origem externa tenta dezenas de contas na VPN da Aurora, consegue entrar com uma delas, usa o endereço interno recebido para um acesso remoto a um servidor financeiro e cria ali uma conta nova no grupo Administradores.

1.5.1. Hipótese e técnicas

A VPN é o serviço remoto exposto que um adversário sem credenciais tenta primeiro (T1133 External Remote Services). Tentativas de senha deixam rastro (T1110 Brute Force), e o rastro que interessa não é o volume de falhas, mas a combinação de falhas em *muitas contas diferentes* vindas da mesma origem com uma sessão bem-sucedida no fim (T1078 Valid Accounts). A hipótese de partida é:

> *Se uma origem externa produz falhas em muitas contas da VPN e depois estabelece uma sessão, os eventos da sessão devem permitir investigar o acesso seguinte.*

O que acontece depois da entrada também é previsível: o adversário usa a sessão para alcançar sistemas internos (T1021.001 Remote Desktop Protocol) e cria uma forma de voltar que não dependa da senha roubada (T1136.001 Create Account: Local Account e T1098 Account Manipulation).

1.5.2. Fontes de dados

- `vpn`: tentativas de autenticação e sessões, com `source.ip`, `source.geo.country_iso_code`, `user.name`, `event.outcome` e, nas sessões estabelecidas, o endereço interno atribuído em `client.nat.ip`.
- `auth`: eventos do Windows no servidor, com `event.code` (4624 para logon, 4720 para criação de conta, 4732 para adição a grupo local), `winlog.logon.type` (10 é logon remoto interativo) e `target.user.name`.

1.5.3. Investigação

Passo 1: o volume de falhas, e por que ele engana. O primeiro impulso é listar as origens com mais falhas.

```
event.dataset:"vpn" and event.outcome:"failure"  →  source.ip, ordenado pela contagem
```

A Tabela 1.4 mostra o resultado. O endereço com mais falhas, 10.20.5.14, com 1.440, é interno. Ao adicionar uma coluna com a contagem única de `user.name`, a leitura muda: essa origem usa uma única conta, `monitor.vpn`, e falha a cada três minutos durante os três dias, sem sucesso. O nome sugere monitoramento; os eventos não revelam a causa das falhas. A origem externa 203.0.113.77 tem menos falhas, 1.026, distribuídas em 62 contas.

Tabela 1.4. Falhas de autenticação na VPN por origem: o volume aponta a sonda, as contas distintas apontam o ataque.

Origem (`source.ip`)	Falhas	Contas distintas	Houve sucesso?
10.20.5.14	1.440	1	não
203.0.113.77	1.026	62	sim
177.39.199.144	2	2	sim

Passo 2: refinar a hipótese para contas distintas com sucesso. A agregação que responde à hipótese é a contagem única de contas por origem, restrita às origens que também aparecem com sucesso. A terceira linha da tabela merece atenção: duas contas, duas falhas e sucesso na mesma origem. Examinada, ela revela dois colaboradores atrás do mesmo endereço residencial, cada um errando a senha uma vez antes de entrar. Contas distintas sozinhas não bastam, o que importa é a ordem de grandeza: 62 contas, entre elas `admin`, `root`, `teste` e `backup`, que não existem na Aurora e denunciam uma lista de dicionário.

```
event.dataset:"vpn" and source.ip:"203.0.113.77" and event.outcome:"success"
```

Dois eventos respondem: a sessão estabelecida com a conta `c.moura` em `2026-03-10T05:17:43Z`, três segundos depois da última falha, e o encerramento do túnel 47 minutos mais tarde. A mesma conta tem sessões legítimas no período, vindas de um endereço residencial brasileiro; a desta madrugada vem de uma origem geolocalizada na Rússia. O evento de sessão também traz o endereço interno que a VPN atribuiu ao atacante: `client.nat.ip` = 10.8.200.23.

Passo 4: o pivô de endereço. A conta `c.moura` tem logons legítimos na própria estação e nos servidores de arquivos, então filtrar pela conta mistura o ataque com o expediente. O pivô certo é o endereço atribuído à sessão suspeita:

```
event.dataset:"auth" and source.ip:"10.8.200.23"
```

O resultado é um logon remoto (`winlog.logon.type`=10) no servidor `SRV-FIN-02`, às 05:24:10, seis minutos e meio depois da entrada.

Passo 5: a persistência. No servidor alcançado, os eventos de gestão de contas completam a história:

```
event.dataset:"auth" and host.name:"SRV-FIN-02" and event.code:("4720" or "4732")
```

Às 05:30:48 a conta `c.moura` cria a conta `svc_relatorios` (4720) e, 47 segundos depois, a adiciona ao grupo local Administradores (4732). O nome imita uma conta de serviço, justamente para passar despercebido numa lista de contas.

1.5.4. Linha do tempo

Horário (UTC, 10/03)	Evento
04:10:03	primeira falha de 203.0.113.77 na VPN
05:17:40	última de 1.026 falhas, em 62 contas
05:17:43	sessão VPN estabelecida como `c.moura`; endereço interno 10.8.200.23
05:24:10	logon remoto em `SRV-FIN-02` a partir de 10.8.200.23
05:30:48	criação da conta `svc_relatorios`
05:31:35	`svc_relatorios` adicionada a Administradores
06:04:43	túnel VPN encerrado

1.5.5. Resposta e detecção derivada

Em uma rede real, esses eventos justificariam investigar a conta `svc_relatorios`, revisar as sessões de `c.moura`, redefinir a credencial comprometida e avaliar o bloqueio da origem. O exercício não executa resposta a incidentes. A detecção candidata abaixo descreve o comportamento observado, sem depender do endereço 203.0.113.77, que poderia mudar.

Listagem 1.1. Detecção derivada do Caso 1, em pseudo-Sigma.

```
title: Muitas contas falhando na VPN a partir da mesma origem, seguidas de sucesso
logsource: { product: vpn }
detection:
  falhas:   event.outcome: failure
  sucesso:  event.outcome: success
  condition: falhas | count(distinct user.name) by source.ip > 15 within 1h
             followed by sucesso from the same source.ip within 1h
falsepositives:
  - NAT compartilhado com poucos usuários (limiar de contas distintas acima de 2)
tags: [attack.t1110, attack.t1133, attack.t1078]
```

Uma segunda regra, de maior valor e menor ruído, observa o que vem depois: criação de conta seguida de adição a grupo administrativo pela mesma conta, no mesmo host, em poucos minutos.

1.5.6. Prática 1: a origem do acesso à VPN

Os participantes recebem o cenário já indexado e a primeira pergunta do caso, e têm de chegar sozinhos à origem do ataque antes da discussão em conjunto.

- **Sem computador** (15 min): acompanhe a Tabela 1.4 e os Passos 1 a 5. Consulta, agregação, pivô e resposta aparecem no texto e nos slides.
- **Com computador** (15 min): `notebooks/caso1.ipynb` refaz as agregações em `pandas`. O vídeo *Caso 1: da força bruta ao privilégio* revisa os pivôs no Hikari isolado (10 min de discussão).
- **O que observar**: a contagem de falhas põe a origem interna no topo. A contagem de contas distintas mede a hipótese e desloca a atenção para 203.0.113.77.

1.5.7. O que a literatura acrescenta

O caso trata o acesso inicial e o primeiro salto, e as duas etapas têm pesquisa própria. Do lado das credenciais, Thomas et al. estimaram, a partir da telemetria anônima de quase 670 mil usuários, que 1,5% dos logons na web usavam credenciais já expostas em vazamentos [TPY+19]: a senha que cedeu na VPN da Aurora não precisaria ter sido adivinhada. Do lado do movimento, o Hopper constrói o grafo de logons entre máquinas internas e infere o caminho e o usuário causal de cada sequência; num conjunto de 15 meses com mais de 780 milhões de logons, detectou 94,5% de mais de 300 cenários de ataque gerando, em média, menos de nove alertas por dia [HDA+21]. O Euler e o Jbeil tratam o mesmo problema como previsão de arestas anômalas em grafos temporais, o segundo sem supor que a rede seja fixa [KH22, KKZ+24].

A ressalva vem do ShadowMove, que move o atacante apenas por conexões já estabelecidas por processos legítimos, sem nova autenticação, sem nova conexão e sem privilégio elevado, e passou despercebido pelas soluções testadas [NWA+20]. A hipótese deste caso depende de um logon novo a partir do endereço atribuído ao atacante; contra um adversário desse tipo, ela precisaria de outra fonte, como a relação entre processo e conexão no EDR.

1.5.8. Exercícios

1. Repita o Passo 1 ordenando por contagem única de `user.name` desde o início. Por que a sonda desaparece do topo?

2. Quanto tempo o atacante levou entre a primeira falha e o sucesso? Quantas tentativas por minuto isso representa, e que limiar de bloqueio por taxa teria interrompido o ataque sem afetar a sonda?

3. Proponha uma hipótese de caça para o caso de o adversário ter usado *password spraying* lento, uma tentativa por conta a cada hora. Que agregação a sustentaria?

1.6. Estudo de Caso 2: O Canal que Respira

O incidente. Em 9 de março, um colaborador da engenharia abre um documento habilitado para macros. Quarenta e um segundos depois, um executável com nome de atualizador do OneDrive inicia no perfil do usuário. Os eventos não mostram a execução da macro nem a instalação do programa. O executável consulta, a cada cinco minutos, um domínio que imita a empresa e conversa com um servidor externo na porta 8443. Na madrugada seguinte, a mesma estação envia 2.292 megabytes a outro servidor externo, em 180 fluxos de tamanho comum.

1.6.1. Hipótese e técnicas

Um implante precisa receber ordens. Na maioria das famílias, isso significa contatar periodicamente um servidor de comando e controle (T1071.001 Application Layer Protocol: Web Protocols), e o contato deixa duas marcas na telemetria: uma consulta de nome e uma conexão, repetidas com regularidade de relógio. Um domínio legítimo de uso corporativo é consultado por muitas estações; o domínio de um implante, por poucas. A hipótese é:

Um implante que pede ordens a um servidor externo gera consultas regulares a um domínio que quase ninguém mais na empresa consulta.

As etapas seguintes da cadeia também têm hipótese própria: o implante tenta passar despercebido com um nome legítimo (T1036.005 Masquerading: Match Legitimate Name or Location), foi iniciado após a abertura de um arquivo pelo usuário (compatível com T1204.002 User Execution: Malicious File, sem prova de entrega por phishing) e depois produziu volume elevado de tráfego de saída, cujo conteúdo não foi observado.

1.6.2. Fontes de dados

- `dns`: consultas de nome, com `dns.question.name`, `host.name` e `source.ip`.
- `firewall`: conexões, com `destination.ip`, `destination.port` e, separadamente, os bytes enviados pela origem (`source.bytes`) e os recebidos por ela (`destination.bytes`).
- `edr`: processos, com `process.name`, `process.executable`, `process.parent.name`, `process.hash.sha256` e argumentos.

1.6.3. Investigação

```
event.dataset:"dns"  →  dns.question.name, ordenado pela contagem
```

O topo é `update.aurora.com.br`, com 8.640 consultas, seguido de serviços comuns com cerca de 1.100 cada. A atualização da empresa é periódica, como um beacon, e é a mais frequente, mas é consultada por todas as 120 estações, de hora em hora. Frequência sozinha aponta a rotina legítima.

Passo 2: frequência com raridade. A agregação que responde à hipótese cruza as duas dimensões: para cada domínio, o número de consultas e o número de estações distintas que o consultam (Tabela 1.5).

```
event.dataset:"dns"  →  dns.question.name: contagem e contagem única de host.name
```

Tabela 1.5. Domínios consultados: só um combina muitas consultas com uma única estação.

Domínio	Consultas	Estações distintas
update.aurora.com.br	8.640	120
api.whatsapp.com	1.109	120
telemetria-aurora-cdn.net	719	1
fornecedor-cabos.com.br	3	1
catalogo-antenas.net	3	1
cotacao-fibra.com	3	1

Quatro domínios têm uma única estação; três deles, três consultas cada, compatíveis com alguém pesquisando um fornecedor. Só `telemetria-aurora-cdn.net` tem centenas de consultas vindas de uma máquina, a `WKS-ENG-117`. O nome imita a empresa, mas é um domínio `.net` que não pertence a ela.

Passo 3: a regularidade. Filtrando as consultas desse domínio e ordenando por `@timestamp`, os intervalos entre consultas consecutivas vão de 285 a 315 segundos, com mediana de 300, de 12:14 de 9 de março até 23:57 de 11 de março, madrugadas incluídas. Na mesma estação, as consultas legítimas à atualização da empresa têm intervalos entre 372 e 6.951 segundos: são horárias, mas sem precisão de relógio. Um humano não navega a cada cinco minutos, com desvio de 15 segundos, por três dias.

Passo 4: o processo e o nome emprestado. Depois de identificar a estação no DNS, o EDR mostra os processos executados nela. A coincidência de máquina e horário orienta a busca, mas não atribui cada consulta DNS a um processo:

```
event.dataset:"edr" and host.name:"WKS-ENG-117" and process.name:"OneDriveUpdater.exe"
```

Na Aurora, `OneDriveUpdater.exe` roda em todas as estações, 361 vezes no período. Em 360 delas, o executável está em `C:\Program Files\Microsoft OneDrive\`, filho de `OneDrive.exe`. Em uma, está em `C:\Users\r.lemos\AppData\Roaming\Microsoft\`, tem outro hash e é filho de `WINWORD.EXE`. O nome engana; o caminho, o hash e o processo pai não. Um nível acima, o evento do `WINWORD.EXE` traz o argumento `Reajuste_Contratos_2026.docm`, um arquivo `.docm` na pasta de downloads. A extensão permite macros; estes eventos não mostram se alguma foi executada.

Passo 5: o volume de saída que só aparece somando. A hipótese de exfiltração pede examinar o volume enviado para fora; o registro de fluxo, sozinho, não mostra o conteúdo. O primeiro impulso é procurar o maior fluxo:

```
event.dataset:"firewall"  →  maior source.bytes
```

O maior fluxo do período, 8,8 GB, vai do servidor de gerenciamento para 10.30.0.10, um destino interno: é o backup noturno. Somando por destino externo o que as estações *enviaram*, a situação muda (Tabela 1.6).

```
event.dataset:"firewall" and not destination.ip:"10.0.0.0/8"  →  soma de source.bytes
    por destination.ip
```

Tabela 1.6. Volume por destino externo: a direção dos bytes separa o download legítimo do envio suspeito.

Destino	Enviado (`source.bytes`)	Recebido (`destination.bytes`)
198.51.100.61	2.292.933.770	baixo
20.190.160.2	82.990.713	3.612.825.366
203.0.113.200	baixo	22.678.362.442

O espelho de atualização, 203.0.113.200, é o destino que mais *entregou* dados às estações: 22,7 GB de download. Quem soma a coluna errada chega nele. O destino que mais *recebeu* dados é 198.51.100.61, com 2.292.933.770 bytes, todos da `WKS-ENG-117`, em 180 fluxos entre 11 e 14,5 MB, das 01:05 às 02:37 de 10 de março. A soma mostra o volume enviado neste cenário; sem inspecionar o conteúdo, ela não prova que os bytes eram dados exfiltrados.

1.6.4. Linha do tempo

Horário (UTC)	Evento
09/03 12:12:30	`WINWORD.EXE` abre `Reajuste_Contratos_2026.docm`
09/03 12:13:11	`OneDriveUpdater.exe` iniciado em `AppData`, filho do Word
09/03 12:14:30	primeira consulta a `telemetria-aurora-cdn.net`; conexão a 198.51.100.44:8443
10/03 01:05:00	início do envio a 198.51.100.61
10/03 02:37:29	fim do envio: 180 fluxos, 2.293 MB
11/03 23:57:48	última consulta do período ao domínio do canal

1.6.5. Resposta e detecção derivada

Em uma rede real, a sequência justificaria isolar a estação, preservar o documento e investigar o domínio e os destinos externos. Essas medidas exigem decisão operacional e não foram executadas no exercício. As detecções candidatas abaixo procuram, respectivamente, periodicidade com raridade e um nome de executável conhecido fora do caminho esperado. Ambas precisam ser testadas contra a telemetria local antes de uso.

Listagem 1.2. Detecções derivadas do Caso 2, em pseudo-Sigma.

```
title: Domínio consultado por uma única estação com regularidade de relógio
logsource: { category: dns }
condition: por (dns.question.name) em 24h:
             count(distinct host.name) <= 2
             and count() >= 100
             and desvio_padrao(intervalo entre consultas) < 0.1 * media(intervalo)
tags: [attack.t1071.001]
---
title: Binário com nome conhecido executado fora do caminho conhecido
logsource: { category: process_creation }
detection:
  nome:    process.name: [OneDriveUpdater.exe, svchost.exe, lsass.exe, explorer.exe]
  caminho: process.executable|startswith: [C:\Program Files\, C:\Windows\System32\]
  condition: nome and not caminho
tags: [attack.t1036.005]
```

1.6.6. Prática 2: o canal que respira

O segundo caso é conduzido em dupla: uma pessoa persegue o domínio e a outra, o volume que sai, e as duas linhas se encontram na mesma estação.

- **Sem computador** (15 min): acompanhe as consultas, as agregações e os cinco passos até a resposta, nas tabelas do capítulo e na aula narrada do caso, em `https://sidneibarbieri.github.io/hikari/minicurso`.
- **Com computador** (15 min): `notebooks/caso2.ipynb` refaz as agregações em

`pandas`. O vídeo *Caso 2: do canal de comando à exfiltração* revisa os pivôs no Hikari isolado (10 min de discussão).

- **O que observar**: o domínio do ataque nunca está no topo da contagem, e o maior fluxo isolado é o backup interno. As duas iscas ensinam a mesma lição: a pergunta certa quase nunca é *qual é o maior*.

1.6.7. O que a literatura acrescenta

A regularidade que o Passo 3 mede à mão é o princípio de detectores automáticos de *beaconing*, como o BAYWATCH, desenhado para identificar máquinas infectadas em redes corporativas de grande porte [HJS+16]. A isca do caso, o domínio legítimo de atualização consultado por todas as estações, tem contrapartida medida na indústria: num estudo sobre seis anos de relatos de falsos positivos de um grande fornecedor, as listas de domínios populares usadas para excluir o benigno não bastaram para evitá-los, o que levou os autores a propor a busca de indicadores de benignidade [LSC+26]. Para a exfiltração, a soma do volume enviado por destino tem paralelo nos detectores que estimam, em tempo real, a informação enviada a cada domínio pelo DNS [ONS24], e a revisão de Sabir et al. organiza as abordagens por aprendizado de máquina [SUBG22].

1.6.8. Exercícios

1. No Passo 3, calcule também a mediana dos intervalos de `update.aurora.com.br` para a mesma estação. Que parâmetro da primeira regra da Listagem 1.2 separa os dois domínios?
2. Por que somar `destination.bytes` aponta o espelho de atualização? Em que tipo de incidente essa seria a coluna certa?
3. O envio ao destino externo começa às 01:05 UTC. Que hipótese de caça por *horário* teria encontrado o envio mesmo sem a hipótese de volume?

1.7. Estudo de Caso 3: Do Mapa do Diretório ao Impacto

O incidente. Na tarde de 10 de março, a conta administrativa `adm.backup` enumera 47 grupos do Active Directory em seis minutos, a partir de uma estação da administração. Vinte minutos depois, a mesma conta instala um serviço remoto no servidor de arquivos `FS01`, apaga as cópias de sombra e renomeia 2.140 arquivos com a extensão `.aurora-lock`; nove minutos depois, repete a sequência no `FS02`, com mais 1.280 arquivos.

1.7.1. Hipótese e técnicas

Neste cenário, a enumeração de grupos antecede o impacto simulado. A hipótese procura uma conta que consulta muitos grupos distintos em poucos minutos (T1069.002 Permission Groups Discovery: Domain Groups). Os eventos do exercício não mostram a composição desses grupos. A telemetria simulada registra consultas à associação de grupos no evento 4799. A hipótese é:

Uma conta que enumera muitos grupos em poucos minutos, fora da rotina de

inventário, pode anteceder movimento lateral. Os eventos seguintes sustentam essa ligação?

As etapas seguintes são representadas por execução remota via serviço (T1569.002 System Services: Service Execution), inibição da recuperação (T1490 Inhibit System Recovery) e o impacto simulado por renomeações em massa (T1486 Data Encrypted for Impact).

1.7.2. Fontes de dados

- `auth`: enumeração de grupos (4799, com `group.name` e `source.ip`), logons interativos (4624 tipo 2, com `host.ip`) e logons de rede (4624 tipo 3).
- `edr`: serviços instalados (`service.name`), processos e linhas de comando (`process.command_line`).
- `fileserver`: renomeações, com `file.path`, `file.extension` e `process.name`.

1.7.3. Investigação

```
event.dataset:"auth" and event.code:"4799"  →  user.name, ordenado pela contagem
```

Há 1.357 eventos 4799 no período. A conta `svc_inventario` responde por 1.296: a ferramenta de inventário confere a cada dez minutos, dia e noite, a associação de três grupos. A conta `adm.backup` aparece com 61. Ordenar por volume coloca a rotina no topo e o ataque em segundo, com vinte vezes menos eventos.

Passo 2: amplitude em vez de volume. O que distingue reconhecimento de rotina é quantos grupos *diferentes* são consultados:

```
event.dataset:"auth" and event.code:"4799"  →  user.name por contagem única de
    group.name
```

O inventário consulta 3 grupos distintos; `adm.backup`, 47, entre eles `Domain Admins`, `Enterprise Admins`, `Backup Operators`, `Remote Desktop Users` e os grupos da própria Aurora, como `Aurora-Servidores-Arquivos`. Os 61 eventos se explicam por consultas repetidas aos grupos de maior valor, típicas de ferramentas que refinam o mapa. Todos saem do mesmo endereço, 10.40.0.140, contra o controlador `DC01`, entre 16:40:03 e 16:46:02.

Passo 3: do endereço à estação. O evento de enumeração não traz o nome da máquina de origem. Os logons interativos trazem:

```
event.dataset:"auth" and host.ip:"10.40.0.140" and winlog.logon.type:"2"
```

O endereço pertence à `WKS-ADM-104`, estação de `e.pires`, que loga nela todos os dias. Às 16:28, doze minutos antes da enumeração, há um logon interativo da conta `adm.backup` na mesma estação. O pivô dá à investigação uma máquina para isolar e

uma pessoa com quem conversar: a conta foi usada por `e.pires`, ou por alguém que controlava a estação dela?

Passo 4: o movimento lateral. Com a conta e a janela de tempo, os logons de rede mostram para onde ela foi:

```
event.dataset:"auth" and user.name:"adm.backup" and winlog.logon.type:"3"
```

Às 17:05:00 a conta faz logon de rede no `FS01`, a partir de 10.40.0.140. Nove segundos depois, o EDR do servidor registra a instalação do serviço `PSEXESVC`, assinatura do PsExec, e em seguida o processo `aurora_upd.exe`, executado a partir de `C:\Windows\Temp\`, filho de `PSEXESVC.exe`.

```
event.dataset:"edr" and process.parent.name:"aurora_upd.exe"
```

Às 17:05:31, `aurora_upd.exe` executa `vssadmin delete shadows /all /quiet`, comando que tenta apagar as cópias de sombra. O registro de criação do processo não confirma o resultado do comando. Ainda assim, na sequência observada, ele justificaria investigar o servidor imediatamente.

Passo 6: a extensão nova, e a rotina que também renomeia. No servidor de arquivos, renomeações em massa acontecem todas as madrugadas: o agente de backup renomeia de 518 a 615 arquivos por noite para `.bak`. Contar renomeações por processo não separa o ataque; separar pela extensão, sim:

```
event.dataset:"fileserver" and event.action:"Arquivo renomeado"  →  (process.name,
    file.extension)
```

Aparecem dois pares: `BackupAgent.exe` com `bak`, nas madrugadas, e `aurora_upd.exe` com `aurora-lock`, na tarde de 10 de março. Ordenando os eventos com a extensão nova por `@timestamp`, o primeiro é no `FS01`, às 17:05:45; o `FS02` começa às 17:14:45. São 3.420 arquivos: 2.140 no `FS01` e 1.280 no `FS02`. O mesmo caminho em dois servidores são dois arquivos, e contar caminhos distintos sem o servidor subestimaria o estrago.

1.7.4. Linha do tempo

Horário (UTC, 10/03)	Evento
16:28:00	logon interativo de `adm.backup` na `WKS-ADM-104`
16:40:03	início da enumeração: 61 consultas, 47 grupos, contra o `DC01`
16:46:02	fim da enumeração
17:05:00	logon de rede no `FS01`; serviço `PSEXESVC` às 17:05:09
17:05:31	`vssadmin delete shadows /all /quiet` no `FS01`
17:05:45	primeiro arquivo renomeado para `.aurora-lock`
17:14:00	mesma sequência no `FS02`
17:30:42	último arquivo renomeado; 3.420 no total

1.7.5. Resposta e detecção derivada

No cenário, a enumeração começou cerca de 26 minutos antes das primeiras renomeações. Uma detecção nessa etapa poderia abrir tempo para investigar; os eventos não permitem afirmar que uma equipe teria reconhecido e contido o incidente nesse intervalo. Por isso as regras candidatas miram o começo da cadeia, e não apenas o impacto.

Listagem 1.3. Detecções derivadas do Caso 3, em pseudo-Sigma.

```
title: Enumeração ampla de grupos por uma conta, fora do inventário
logsource: { product: windows, service: security }
detection:
  enumeracao: event.code: 4799
  inventario: user.name: [svc_inventario]
  condition: enumeracao and not inventario
             | count(distinct group.name) by user.name > 20 within 15m
tags: [attack.t1069.002]
---
title: Cópias de sombra apagadas por processo iniciado via serviço remoto
logsource: { category: process_creation }
detection:
  sombras: process.command_line|contains|all: [vssadmin, delete, shadows]
  condition: sombras
level: critical
tags: [attack.t1490]
```

1.7.6. Prática 3: do mapa do diretório ao impacto

O terceiro caso é cronometrado como um incidente: a turma recebe o alerta de arquivos renomeados e precisa reconstruir o que veio antes.

- **Sem computador** (10 min): acompanhe os seis passos, as consultas, a linha do tempo e a resposta no texto e na aula narrada do caso, em `https://sidneibarbieri.github.io/hikari/minicurso`.
- **Com computador** (10 min): `notebooks/caso3.ipynb` refaz as agregações em `pandas`. O vídeo *Caso 3: do mapa do diretório ao impacto* revisa a cadeia no Hikari isolado (10 min de discussão). A turma propõe a regra de detecção e discute seus falsos positivos.
- **O que observar**: a enumeração começa cerca de 26 minutos antes das primeiras renomeações. Uma detecção nessa etapa abriria uma oportunidade de investigação; o exercício não mede se a equipe conseguiria conter o incidente a tempo.

1.7.7. O que a literatura acrescenta

A detecção de *ransomware* por comportamento de E/S tem uma década de pesquisa, do UNVEIL [KAM+16] ao sistema de arquivos com autorrecuperação ShieldFS [CGZ+16]. Duas observações recentes interessam ao caçador. A primeira é o custo: van Sloun et al. mediram que monitorar até atributos simples, como a entropia de um *buffer*, pode aumentar o tempo de execução em até 350% [vSWW+25]. A segunda é a evasão: *ransomware* evasivo imita programas benignos ou enfraquece os sinais de E/S durante a cifra, e o ERW-Radar responde com a repetitividade das operações e a distribuição dos bytes dos arquivos escritos [ZZW+25]. Este caso usa a extensão nova nas renomeações como sinal de impacto simulado e examina a enumeração anterior. O intervalo entre os dois sinais abre uma hipótese de detecção precoce, não prova que o dano poderia ter sido evitado.

1.7.8. Exercícios

1. Refaça o Passo 1 com a contagem única de `group.name`. Qual limiar da primeira regra da Listagem 1.3 separaria o ataque do inventário com folga, e que outra rotina legítima poderia ultrapassá-lo?
2. A enumeração durou seis minutos e as renomeações começaram cerca de vinte minutos depois. Desenhe o fluxo de resposta automatizada que teria contido a conta nesse intervalo, e diga que risco ele traz.
3. Por que `PSEXESVC` é um bom sinal de caça, mas uma detecção ruidosa em ambientes que usam PsExec na administração legítima? Que contexto reduziria o ruído?

1.8. Da Caçada à Detecção, Limites e Conclusões

1.8.1. O que os três casos têm em comum

1. **Formule uma hipótese observável.** Muitas contas por origem, consultas periódicas de uma estação e enumeração ampla são comportamentos que podem ser procurados sem conhecer antes o IP ou o domínio do adversário.
2. **Teste a explicação alternativa.** Compare a origem suspeita à sonda, o domínio raro ao atualizador e a conta suspeita ao inventário. Sem essa comparação, a contagem não distingue ataque de rotina.
3. **Siga o vínculo registrado.** O endereço atribuído pela VPN liga a sessão ao logon remoto; a estação liga o DNS ao processo; o endereço de origem liga a enumeração ao host. Cada ligação deve existir nos eventos, e pode falhar se o campo ou a janela temporal estiverem ausentes.
4. **Declare o limite da conclusão.** Bytes enviados não identificam o conteúdo. Renomeações e exclusão de cópias de sombra são compatíveis com a sequência simulada de *ransomware*, mas não demonstram cifra criptográfica. As regras propostas são hipóteses de detecção a validar, não regras prontas para produção.

1.8.2. O que medir e o que não inferir

Encontrar um incidente não é a única medida possível de uma caçada. A Tabela 1.7 reúne medidas candidatas para avaliar cobertura, trabalho e resultado. Elas não foram estimadas nos três casos sintéticos; cada uma exige denominador, período e contexto operacional para ser interpretada.

Nos três casos deste capítulo, a última linha é a que mais pesa: o processo suspeito do Caso 2 consultou o domínio periódico por mais de doze horas antes do envio volumoso, e a enumeração do Caso 3 começou cerca de 26 minutos antes das primeiras renomeações. Os horários mostram oportunidade de investigar sinais anteriores ao impacto simulado; não medem quanto tempo uma equipe real levaria para reconhecer, decidir e conter o incidente.

1.8.3. Como ensinar o raciocínio de caça

O exercício deve deixar visível a decisão que muda a investigação. Antes de revelar a segunda coluna da Tabela 1.4, peça que a turma escolha uma origem apenas pela contagem

Tabela 1.7. Métricas de uma equipe de caça, e o que cada uma distorce se virar meta.

Métrica	O que mede	O que distorce sozinha
Hipóteses testadas e documentadas	ritmo de trabalho e memória da equipe	incentiva hipóteses fáceis e repetidas
Técnicas do ATT&CK com caçada documentada	cobertura do que já se procurou	cobertura pode não ser boa métrica de detecção [VIR+24]
Detecções derivadas e a taxa de falso positivo delas após 30 dias	o que a caça devolveu à operação	sem a segunda metade, premia regra ruidosa
Lacunas de telemetria descobertas e corrigidas	melhora do ambiente, e não do relatório	depende de alguém do outro lado corrigir
Tempo entre o primeiro sinal na telemetria e a caçada	atraso real da defesa	só existe quando a caçada encontra algo

de falhas. A comparação com contas distintas permite explicar por que a primeira escolha não responde à hipótese. No segundo caso, separe consultas frequentes de consultas periódicas feitas por uma única estação. No terceiro, peça uma hipótese de detecção antes de mostrar os eventos de renomeação: o ganho didático está em localizar o sinal que antecede o impacto simulado.

Em cada discussão, a resposta deve incluir a consulta, a agregação, o evento que autoriza o pivô e uma explicação alternativa. Quem acompanha sem computador dispõe dessas peças nas tabelas e linhas do tempo. Quem executa os cadernos pode testar se outra janela ou outro limiar mudaria a conclusão. Esse confronto ensina mais que acertar o valor final: mostra em que ponto a evidência sustentou uma inferência e onde ainda falta observar.

1.8.4. Desafios e tendências

A pesquisa oferece maneiras de apoiar a investigação, mas seus limites importam para quem aprende a caçar. Uma linha automatiza a reconstrução dos eventos. Os sistemas por grafo de proveniência já reconstroem histórias de ataque e resumem grafos enormes (Seção 1.3), mas a adoção esbarra no custo de operação e na qualidade do que entregam ao analista [DLJ+23, JBEM+25, BJL+25]. Outra linha investiga modelos de linguagem: Hammar, Alpcan e Lupu ajustaram um modelo leve para planejar a resposta a incidentes, provaram que a probabilidade de alucinação é limitada sob as premissas que declaram, e relatam tempos de recuperação até 22% menores que os de modelos de fronteira nos cenários avaliados [HAL26]. A mesma promessa vale para a caça, com o mesmo cuidado: o modelo pode propor hipóteses e consultas, mas a conclusão precisa ser conferida contra a evidência. Também é preciso considerar o adversário adaptativo, que evade regras de SIEM e detectores aprendidos [UHH+24, GHWB23, MWW+23]; quanto mais automática a detecção, mais valor tem quem formula a hipótese que ela ainda não conhece.

1.8.5. Limites

O cenário Aurora é sintético e pequeno: 49.277 eventos em três dias, com seis fontes de dados limpas e normalizadas. Ambientes reais têm ordens de grandeza mais eventos, campos ausentes, relógios dessincronizados e fontes que param de enviar dados sem avi-

sar, e uma parte relevante do trabalho de caça é lidar com isso. Os ataques foram escritos para ter uma resposta única e verificável, o que os torna mais limpos que incidentes reais, nos quais o adversário comete menos erros e deixa menos rastro. As regras em pseudo-Sigma ilustram a lógica e não estão prontas para produção: exigem ajuste de limiares ao ambiente, lista de exceções mantida e teste contra dados históricos. Por fim, a periodicidade do Caso 2 é regular por construção; implantes reais variam o intervalo com *jitter* maior, e detectores de *beaconing* podem empregar análise espectral e autocorrelação para lidar com variação nos intervalos [HJS+16].

1.8.6. Conclusões

Os casos permitem praticar uma sequência que pode ser transferida para outras fontes de dados: formular comportamento observável, escolher a agregação que o mede, confrontar uma explicação benigna e seguir apenas os vínculos presentes na telemetria. Na Aurora, essa sequência identifica a sessão de VPN seguida da criação de um administrador, um canal periódico associado a volume enviado a um destino externo e a enumeração que antecede renomeações em massa. A terceira cadeia é uma simulação de *ransomware*; seus eventos não provam que os arquivos foram cifrados. O valor das regras derivadas depende de teste com dados locais, medição de falsos positivos e revisão dos limiares. O exercício ensina a justificar essas decisões; não substitui a investigação de um ambiente real.

Agradecimentos

Os autores agradecem às equipes que participaram das competições conduzidas no Hikari, cujas dúvidas e reclamações orientaram o desenho dos estudos de caso.

Apêndice: as perguntas do cenário

Este apêndice reúne as vinte perguntas do cenário Aurora, as buscas, as respostas conferidas por código e as dicas para refinar cada hipótese. Assim, o leitor pode refazer e discutir os três casos sem consultar um gabarito externo.

Caso 1 — Da força bruta ao privilégio

Hipótese: Uma origem externa produz falhas em muitas contas da VPN e depois estabelece uma sessão. Os eventos da sessão permitem investigar o acesso seguinte?

A Origem do Acesso à VPN *Médio*

A VPN registrou milhares de falhas de autenticação no período. Informe o endereço de origem que tentou muitas contas diferentes e conseguiu estabelecer uma sessão.

```
event.dataset:"vpn" and event.outcome:"failure"  →  agrupar source.ip por contagem ú
    nica de user.name
```

Resposta: `203.0.113.77`
Dica: O endereço com mais falhas não é o do ataque: conte contas distintas por origem, e não eventos.

O Tamanho da Lista *Fácil*

Quantas contas distintas a origem do ataque tentou na VPN?

```
event.dataset:"vpn" and source.ip:"203.0.113.77"  →  contagem única de user.name
```

Resposta: `62`
Dica: Filtre pela origem do ataque e conte valores distintos de user.name, inclusive a que cedeu.

A Conta Que Cedeu *Fácil*

Qual conta a origem do ataque conseguiu usar para abrir a sessão na VPN?

```
event.dataset:"vpn" and source.ip:"203.0.113.77" and event.outcome:"success"
```

Resposta: `c.moura`
Dica: Entre os eventos da origem do ataque, separe os de sucesso.

O Minuto Zero *Médio*

Informe o carimbo de tempo, como o campo @timestamp o guarda, da sessão VPN que o atacante estabeleceu.

```
event.dataset:"vpn" and source.ip:"203.0.113.77" and event.action:"Sessão VPN
    estabelecida"
```

Resposta: `2026-03-10T05:17:43.000Z`
Dica: É o único evento de sucesso da origem do ataque com a ação de sessão estabelecida.

A Ponte Para Dentro *Difícil*

Com a sessão aberta, o atacante recebeu um endereço interno da VPN e o usou para um logon remoto. Em qual servidor?

```
event.dataset:"auth" and source.ip:"10.8.200.23" and winlog.logon.type:"10"
```

Resposta: `SRV-FIN-02`
Dica: O endereço atribuído fica no evento da sessão (client.nat.ip). Procure-o como origem nos eventos de autenticação.

O Novo Administrador *Difícil*

No servidor acessado, uma conta foi criada e posta no grupo Administradores. Qual?

```
event.dataset:"auth" and host.name:"SRV-FIN-02" and event.code:("4720" or "4732")
```

Resposta: `svc_relatorios`
Dica: Procure os eventos 4720 e 4732 no servidor e leia a conta alvo (target.user.name).

Caso 2 — O canal que respira

Hipótese: Um implante que pede ordens a um servidor externo gera consultas regulares a um domínio que quase ninguém mais na empresa consulta.

O Domínio Que Só Uma Máquina Conhece *Médio*

Uma estação consulta um domínio externo com regularidade de relógio, e nenhuma outra estação o consulta. Informe o domínio.

```
event.dataset:"dns"  →  agrupar dns.question.name com contagem única de host.name
```

Resposta: `telemetria-aurora-cdn.net`
Dica: O domínio mais consultado da empresa é legítimo e aparece em todas as estações.

Procure o que tem muitas consultas vindas de uma única estação.

A Estação Que Chama *Fácil*

Qual estação consulta o domínio do canal?

```
event.dataset:"dns" and dns.question.name:"telemetria-aurora-cdn.net"
```

Resposta: `WKS-ENG-117`
Dica: Filtre as consultas pelo domínio encontrado e leia host.name.

O Ritmo do Batimento *Difícil*

De quanto em quanto tempo, em segundos, a estação consulta o domínio? Informe a mediana dos intervalos entre consultas consecutivas, arredondada para a dezena.

```
event.dataset:"dns" and dns.question.name:"telemetria-aurora-cdn.net"  →  diferenças
    entre @timestamp
```

Resposta: `300`
Dica: Ordene as consultas por @timestamp e subtraia cada uma da anterior; o jitter é pequeno.

O Nome Emprestado *Médio*

O processo que conversa com o servidor do canal tem nome de atualizador legítimo. Informe o caminho completo do executável na estação infectada.

```
event.dataset:"edr" and host.name:"WKS-ENG-117" and process.name:"OneDriveUpdater.exe"
```

Resposta:

```
C:\Users\r.lemos\AppData\Roaming\Microsoft\OneDriveUpdater.exe
```

Dica: O mesmo nome existe em todas as estações, em Program Files. Na estação infectada, compare process.executable e process.hash.sha256.

Quem Soltou o Implante *Médio*

Qual processo iniciou o executável malicioso?

```
event.dataset:"edr" and process.executable:*AppData*
```

Resposta: `WINWORD.EXE`
Dica: Leia process.parent.name no evento do executável fora de Program Files.

O Destino do Volume *Difícil*

Somando o que cada destino externo recebeu (bytes enviados pela origem), qual destino recebeu mais dados da estação infectada?

```
event.dataset:"firewall" and host.name:"WKS-ENG-117" and not destination.ip:10.0.0.0/8
    →  soma de source.bytes por destination.ip
```

Resposta: `198.51.100.61`
Dica: Nenhum fluxo isolado chama atenção: some source.bytes por destination.ip. O maior fluxo do período é o backup, que vai para um endereço interno.

Quanto Saiu *Difícil*

Quantos megabytes (10^6 bytes), arredondados para baixo, a estação enviou ao destino do envio suspeito?

```
event.dataset:"firewall" and destination.ip:"198.51.100.61"  →  soma de source.bytes
```

Resposta: `2292`
Dica: Some source.bytes dos fluxos da estação para o destino do envio suspeito e divida por 1.000.000.

Caso 3 — Do mapa do diretório ao impacto

Hipótese: Uma conta enumera muitos grupos em poucos minutos, fora da rotina de inventário. Os eventos seguintes ligam essa conta ao movimento lateral?

Quem Mapeou o Diretório *Médio*
O controlador de domínio registrou enumeração de associação de grupos (evento 4799). Além da rotina de inventário, uma conta enumerou dezenas de grupos. Qual?

```
event.dataset:"auth" and event.code:"4799"  →  agrupar user.name por contagem única de
    group.name
```

Resposta: `adm.backup`
Dica: A conta com mais eventos de enumeração é o inventário, que confere sempre os mesmos três grupos. Conte grupos distintos por conta, e não eventos.

A Amplitude do Mapa *Fácil*
Quantos grupos distintos essa conta enumerou?

```
event.dataset:"auth" and event.code:"4799" and user.name:"adm.backup"  →  contagem ú
    nica de group.name
```

Resposta: `47`
Dica: Algumas consultas se repetem: conte valores distintos de group.name.

De Onde Partiu *Difícil*
Os eventos de enumeração só trazem o endereço de origem. Qual o nome da estação que usa esse endereço?

```
event.dataset:"auth" and host.ip:"10.40.0.140" and winlog.logon.type:"2"
```

Resposta: `WKS-ADM-104`
Dica: Leia source.ip nos eventos 4799 da conta e procure o mesmo endereço em host.ip nos logons interativos.

O Primeiro Servidor Atingido *Médio*
Arquivos passaram a ganhar uma extensão estranha em mais de um servidor. Em qual servidor isso começou?

```
event.dataset:"fileserver" and file.extension:"aurora-lock"  →  ordenar por @timestamp
```

Resposta: `FS01`
Dica: Filtre os arquivos renomeados com a extensão nova e ordene por @timestamp.

O Processo Que Renomeia *Fácil*
Qual processo renomeou os arquivos para a extensão nova?

```
event.dataset:"fileserver" and file.extension:"aurora-lock"  →  agrupar process.name
```

Resposta: `aurora_upd.exe`
Dica: O agente de backup renomeia em massa toda madrugada. Olhe só os arquivos com a extensão nova.

Sem Volta Atrás *Médio*
Antes de renomear, o processo apagou as cópias de sombra. Informe a linha de comando exatamente como registrada.

```
event.dataset:"edr" and process.parent.name:"aurora_upd.exe"
```

Resposta: `vssadmin delete shadows /all /quiet`
Dica: Procure no EDR os processos filhos do processo associado às renomeações e leia process.command_line.

O Tamanho do Estrago *Médio*
Quantos arquivos ganharam a extensão nova, somando todos os servidores?

```
event.dataset:"fileserver" and file.extension:"aurora-lock"  →  contagem
```

Resposta: `3420`
Dica: Conte os eventos de renomeação com a extensão nova, sem filtrar por servidor.

Referências

[AAM22] Bushra A. AlAhmadi, Louise Axon, and Ivan Martinovic. 99% false positives: A qualitative study of SOC analysts' perspectives on security alarms. In *31st USENIX Security Symposium*. USENIX Association, 2022.

[ANM+21] Abdulellah Alsaheel, Yuhong Nan, Shiqing Ma, Le Yu, Gregory Walkup, Z. Berkay Celik, Xiangyu Zhang, and Dongyan Xu. ATLAS: A sequence-based learning approach for attack investigation. In *30th USENIX Security Symposium*. USENIX Association, 2021.

[ASSO25] Bader Al-Sada, Alireza Sadighian, and Gabriele Oligeri. MITRE ATT&CK: State of the art and way forward. *ACM Computing Surveys*, 57(1):12:1–12:37, 2025.

[B+23] David Bianco et al. The PEAK threat hunting framework. White paper, Splunk Inc., 2023.

[BBC+25] Sidnei Barbieri, Bruno Moreira Camargos Belo, Leonardo Chahud, Leonardo Vaz de Meneses, Cesar Marcondes, and Lourenço Alves Pereira Júnior. HIKARI — desafios reais, ameaças ocultas: Uma plataforma de threat hunting gamificado. In *Anais do Simpósio Brasileiro de Cibersegurança (SBSeg)*. Sociedade Brasileira de Computação, 2025.

[Bet18] Betaalvereniging Nederland. TaHiTI: Targeted hunting integrating threat intelligence. Technical report, Betaalvereniging Nederland, 2018.

[BH22] Bibek Bhattarai and H. Howie Huang. SteinerLog: Prize collecting the audit logs for threat hunting on enterprise network. In *ACM Asia Conference on Computer and Communications Security (AsiaCCS)*. ACM, 2022.

[Bia13] David J. Bianco. The pyramid of pain. Enterprise Detection & Response (blog), 2013.

[BJL+25] Tristan Bilot, Baoxiang Jiang, Zefeng Li, Nour El Madhoun, Khaldoun Al Agha, Anis Zouaoui, and Thomas Pasquier. Sometimes simpler is better: A comprehensive analysis of state-of-the-art provenance-based intrusion detection systems. In *34th USENIX Security Symposium*, pages 7193–7212. USENIX Association, 2025.

[BRPR24] Priyanka Badva, Kopo M. Ramokapane, Eleonora Pantano, and Awais Rashid. Unveiling the hunter-gatherers: Exploring threat hunting practices and challenges in cyber defense. In *33rd USENIX Security Symposium*. USENIX Association, 2024.

[CGZ+16] Andrea Continella, Alessandro Guagnelli, Giovanni Zingaro, Giulio De Pasquale, Alessandro Barenghi, Stefano Zanero, and Federico Maggi. ShieldFS: A self-healing, ransomware-aware filesystem. In *32nd Annual Conference on Computer Security Applications (ACSAC)*, pages 336–347, 2016.

[CLL+24] Zijun Cheng, Qiujian Lv, Jinyuan Liang, Yan Wang, Degang Sun, Thomas Pasquier, and Xueyuan Han. Kairos: Practical intrusion detection and investigation using whole-system provenance. In *IEEE Symposium on Security and Privacy (SP)*. IEEE, 2024.

[CPB13] Sergio Caltagirone, Andrew Pendergast, and Christopher Betz. The diamond model of intrusion analysis. Technical report, Center for Cyber Intelligence Analysis and Threat Research, 2013.

[DAR20] DARPA. Transparent computing engagement data releases, 2020.

[DLJ+23] Feng Dong, Shaofei Li, Peng Jiang, Ding Li, Haoyu Wang, Liangyi Huang, Xusheng Xiao, Jiedong Chen, Xiapu Luo, Yao Guo, and Xiangqun Chen. Are we there yet? An industrial viewpoint on provenance-based endpoint detection and response tools. In *ACM SIGSAC Conference on Computer and Communications Security (CCS)*, pages 2396–2410. ACM, 2023.

[DZNM23] Hailun Ding, Juan Zhai, Yuhong Nan, and Shiqing Ma. AirTag: Towards automated attack investigation by unsupervised learning with log texts. In *32nd USENIX Security Symposium*. USENIX Association, 2023.

[Ela24] Elastic. Elastic common schema (ECS) reference. Documentação oficial, 2024.

[FGL+22] Pengcheng Fang, Peng Gao, Changlin Liu, Erman Ayday, Kangkook Jee, Ting Wang, Yanfang (Fanny) Ye, Zhuotao Liu, and Xusheng Xiao. Back-propagating system dependency impact for attack investigation. In *31st USENIX Security Symposium*. USENIX Association, 2022.

[GHWB23] Akul Goyal, Xueyuan Han, Gang Wang, and Adam Bates. Sometimes, you aren't what you do: Mimicry attacks against provenance graph host intrusion detection systems. In *Network and Distributed System Security Symposium (NDSS)*. The Internet Society, 2023.

[HAL26] Kim Hammar, Tansu Alpcan, and Emil C. Lupu. Incident response planning using a lightweight large language model with reduced hallucination. In *Network and Distributed System Security Symposium (NDSS)*. The Internet Society, 2026.

[HBM20] Wajih Ul Hassan, Adam Bates, and Daniel Marino. Tactical provenance analysis for endpoint detection and response systems. In *IEEE Symposium on Security and Privacy (SP)*. IEEE, 2020.

[HCA11] Eric M. Hutchins, Michael J. Cloppert, and Rohan M. Amin. Intelligence-driven computer network defense informed by analysis of adversary campaigns and intrusion kill chains. Technical report, Lockheed Martin Corporation, 2011.

[HDA+21] Grant Ho, Mayank Dhiman, Devdatta Akhawe, Vern Paxson, Stefan Savage, Geoffrey M. Voelker, and David A. Wagner. Hopper: Modeling and detecting lateral movement. In *30th USENIX Security Symposium*. USENIX Association, 2021.

[HGL+19] Wajih Ul Hassan, Shengjian Guo, Ding Li, Zhengzhang Chen, Kangkook Jee, Zhichun Li, and Adam Bates. NoDoze: Combatting threat alert fatigue with automated provenance triage. In *Network and Distributed System Security Symposium (NDSS)*. The Internet Society, 2019.

[HJS+16] Xin Hu, Jiyong Jang, Marc Ph. Stoecklin, Ting Wang, Douglas L. Schales, Dhilung Kirat, and Josyula R. Rao. BAYWATCH: Robust beaconing detection to identify infected hosts in large-scale enterprise networks. In *46th Annual IEEE/IFIP International Conference on Dependable Systems and Networks (DSN)*, pages 479–490, 2016.

[HNDB20] Wajih Ul Hassan, Mohammad A. Noureddine, Pubali Datta, and Adam Bates. OmegaLog: High-fidelity attack investigation via transparent multi-layer log analysis. In *Network and Distributed System Security Symposium (NDSS)*. The Internet Society, 2020.

[HPB+20] Xueyuan Han, Thomas F. J.-M. Pasquier, Adam Bates, James Mickens, and Margo I. Seltzer. Unicorn: Runtime provenance-based detector for advanced persistent threats. In *Network and Distributed System Security Symposium (NDSS)*. The Internet Society, 2020.

[ICG+23] Muhammad Adil Inam, Yinfang Chen, Akul Goyal, Jason Liu, Jaron Mink, Noor Michael, Sneha Gaur, Adam Bates, and Wajih Ul Hassan. SoK: History is a vast early warning system: Auditing the provenance of system intrusions. In *IEEE Symposium on Security and Privacy (SP)*, pages 2620–2638. IEEE, 2023.

[JBEM+25] Baoxiang Jiang, Tristan Bilot, Nour El Madhoun, Khaldoun Al Agha, Anis Zouaoui, Shahrear Iqbal, Xueyuan Han, and Thomas Pasquier. Orthrus: Achieving high quality of attribution in provenance-based intrusion detection systems. In *34th USENIX Security Symposium*. USENIX Association, 2025.

[JBHFB23] Kailani R. Jones, Dalton A. Brucker-Hahn, Bradley Fidler, and Alexandru G. Bardas. Work-from-home and COVID-19: Trajectories of endpoint security management in a security operations center. In *32nd USENIX Security Symposium*. USENIX Association, 2023.

[JCNP25] Fatemeh Jalalvand, Mohan Baruwal Chhetri, Surya Nepal, and Cécile Paris. Alert prioritisation in security operations centres: A systematic survey on criteria and methods. *ACM Computing Surveys*, 57(2):42:1–42:36, 2025.

[JKL+24] Beomjin Jin, Eunsoo Kim, Hyunwoo Lee, Elisa Bertino, Doowon Kim, and Hyoungshick Kim. Sharing cyber threat intelligence: Does it really help? In *Network and Distributed System Security Symposium (NDSS)*. The Internet Society, 2024.

[JXN+24] Zian Jia, Yun Xiong, Yuhong Nan, Yao Zhang, Jinjing Zhao, and Mi Wen. MAGIC: Detecting advanced persistent threats via masked graph representation learning. In *33rd USENIX Security Symposium*. USENIX Association, 2024.

[KAM+16] Amin Kharraz, Sajjad Arshad, Collin Mulliner, William Robertson, and Engin Kirda. UNVEIL: A large-scale, automated approach to detecting ransomware. In *25th USENIX Security Symposium*. USENIX Association, 2016.

[Ken15] Alexander D. Kent. Comprehensive, multi-source cyber-security events. Los Alamos National Laboratory, 2015.

[KH22] Isaiah J. King and H. Howie Huang. Euler: Detecting network lateral movement via scalable temporal link prediction. In *Network and Distributed System Security Symposium (NDSS)*. The Internet Society, 2022.

[KKZ+24] Joseph Khoury, Dorde Klisura, Hadi Zanddizari, Gonzalo De La Torre Parra, Peyman Najafirad, and Elias Bou-Harb. Jbeil: Temporal graph-based inductive learning to infer lateral movement in evolving enterprise networks. In *IEEE Symposium on Security and Privacy (SP)*. IEEE, 2024.

[KS06] Karen Kent and Murugiah Souppaya. Guide to computer security log management. Technical Report SP 800-92, NIST, 2006.

[KSB+19] Faris Bugra Kokulu, Ananta Soneji, Tiffany Bao, Yan Shoshitaishvili, Ziming Zhao, Adam Doupé, and Gail-Joon Ahn. Matched and mismatched SOCs: A qualitative study on security operations center issues. In *ACM SIGSAC Conference on Computer and Communications Security (CCS)*. ACM, 2019.

[LB16] Robert M. Lee and David Bianco. Generating hypotheses for successful threat hunting. White paper, SANS Institute, 2016.

[LDX+24] Shaofei Li, Feng Dong, Xusheng Xiao, Haoyu Wang, Fei Shao, Jiedong Chen, Yao Guo, Xiangqun Chen, and Ding Li. NodLink: An online system for fine-grained APT attack detection and investigation. In *Network and Distributed System Security Symposium (NDSS)*. The Internet Society, 2024.

[LSC+26] Daiping Liu, Danyu Sun, Zhenhua Chen, Shu Wang, and Zhou Li. Indicator of benignity: An industry view of false positive in malicious domain detection and its mitigation. In *Network and Distributed System Security Symposium (NDSS)*. The Internet Society, 2026.

[MD24] William P. Maxam, III and James C. Davis. An interview study on third-party cyber threat hunting processes in the U.S. department of homeland security. In *33rd USENIX Security Symposium*. USENIX Association, 2024.

[MEGV19] Sadegh M. Milajerdi, Birhanu Eshete, Rigel Gjomemo, and V. N. Venkatakrishnan. POIROT: Aligning attack behavior with kernel audit records for cyber threat hunting. In *ACM SIGSAC Conference on Computer and Communications Security (CCS)*. ACM, 2019.

[MGE+19] Sadegh Momeni Milajerdi, Rigel Gjomemo, Birhanu Eshete, R. Sekar, and V. N. Venkatakrishnan. HOLMES: Real-time APT detection through correlation of suspicious information flows. In *IEEE Symposium on Security and Privacy (SP)*. IEEE, 2019.

[MLG+26] Yuhan Meng, Shaofei Li, Jiaping Gui, Peng Jiang, and Ding Li. KnowHow: Automatically applying high-level CTI knowledge for interpretable and accurate provenance analysis. In *Network and Distributed System Security Symposium (NDSS)*. The Internet Society, 2026.

[MP14] Jelena Mirkovic and Peter A. H. Peterson. Class capture-the-flag exercises. In *2014 USENIX Summit on Gaming, Games, and Gamification in Security Education (3GSE 14)*. USENIX Association, 2014.

[MWW+23] Kunal Mukherjee, Joshua Wiedemeier, Tianhao Wang, James Wei, Feng Chen, Muhyun Kim, Murat Kantarcioglu, and Kangkook Jee. Evading provenance-based ML detectors with adversarial system actions. In *32nd USENIX Security Symposium*. USENIX Association, 2023.

[Nat24] National Institute of Standards and Technology. The NIST cybersecurity framework (CSF) 2.0. Technical Report CSWP 29, NIST, 2024.

[NPD23] Boubakr Nour, Makan Pourzandi, and Mourad Debbabi. A survey on threat hunting in enterprise networks. *IEEE Communications Surveys & Tutorials*, 25(4):2299–2324, 2023.

[NRSS25] Alex Nelson, Sanjay Rekhi, Murugiah Souppaya, and Karen Scarfone. Incident response recommendations and considerations for cybersecurity risk management: A CSF 2.0 community profile. Technical Report NIST SP 800-61r3, National Institute of Standards and Technology, 2025.

[NWA+20] Amirreza Niakanlahiji, Jinpeng Wei, Md Rabbi Alam, Qingyang Wang, and Bei-Tseng Chu. ShadowMove: A stealthy lateral movement strategy. In *29th USENIX Security Symposium*. USENIX Association, 2020.

[OALU22] Harun Oz, Ahmet Aris, Albert Levi, and A. Selcuk Uluagac. A survey on ransomware: Evolution, taxonomy, and defense solutions. *ACM Computing Surveys*, 54(11s):238:1–238:37, 2022.

[ONS24] Yarin Ozery, Asaf Nadler, and Asaf Shabtai. Information based heavy hitters for real-time DNS data exfiltration detection. In *Network and Distributed System Security Symposium (NDSS)*. The Internet Society, 2024.

[SAM+18] Blake E. Strom, Andy Applebaum, Doug P. Miller, Kathryn C. Nickels, Adam G. Pennington, and Cody B. Thomas. MITRE ATT&CK: Design and philosophy. Technical Report MTR180312, The MITRE Corporation, McLean, VA, 2018.

[SCP21] Daniel Schlette, Marco Caselli, and Günther Pernul. A comparative study on cyber threat intelligence: The security incident response perspective. *IEEE Communications Surveys & Tutorials*, 23(4), 2021.

[ŠČVB21] Valdemar Švábenský, Pavel Čeleda, Jan Vykopal, and Silvia Brišáková. Cybersecurity knowledge and skills taught in capture the flag challenges. *Computers & Security*, 102, 2021.

[SDJ+23] Nan Sun, Ming Ding, Jiaojiao Jiang, Weikang Xu, Xiaoxing Mo, Yonghang Tai, and Jun Zhang. Cyber threat intelligence mining for proactive cybersecurity defense: A survey and new perspectives. *IEEE Communications Surveys & Tutorials*, 25(3):1748–1774, 2023.

[SEC+24] Daniel Schlette, Philip Empl, Marco Caselli, Thomas Schreck, and Günther Pernul. Do you play it by the books? A study on incident response playbooks and influencing factors. In *IEEE Symposium on Security and Privacy (SP)*. IEEE, 2024.

[SGV21] Kiavash Satvat, Rigel Gjomemo, and V. N. Venkatakrishnan. Extractor: Extracting attack behavior from threat reports. In *IEEE European Symposium on Security and Privacy (EuroS&P)*. IEEE, 2021.

[SHW+25] Armin Sarabi, Ziyuan Huang, Chenlan Wang, Tai Karir, and Mingyan Liu. The ransomware decade: The creation of a fine-grained dataset and a longitudinal study. In *34th USENIX Security Symposium*, pages 4799–4818. USENIX Association, 2025.

[Sig24] SigmaHQ. Sigma: Generic signature format for SIEM systems. Repositório de código aberto, 2024.

[SLB+24] Xiangmin Shen, Zhenyuan Li, Graham Burleigh, Lingzhi Wang, and Yan Chen. Decoding the MITRE engenuity ATT&CK enterprise evaluation: An analysis of EDR performance in real-world environments. In *ACM Asia Conference on Computer and Communications Security (AsiaCCS)*. ACM, 2024.

[SMB+25] Aakanksha Saha, James Mattei, Jorge Blasco, Lorenzo Cavallaro, Daniel Votipka, and Martina Lindorfer. Expert insights into advanced persistent threats: Analysis, attribution, and challenges. In *34th USENIX Security Symposium*, pages 2185–2204. USENIX Association, 2025.

[Sqr16] Sqrrl Data. A framework for cyber threat hunting. White paper, Sqrrl Data, Inc., 2016.

[SUBG22] Bushra Sabir, Faheem Ullah, Muhammad Ali Babar, and Raj Gaire. Machine learning for detecting data exfiltration: A review. *ACM Computing Surveys*, 54(3):50:1–50:47, 2022.

[ŠVČ20] Valdemar Švábenský, Jan Vykopal, and Pavel Čeleda. What are cybersecurity education papers about? A systematic literature review of SIGCSE and ITiCSE conferences. In *51st ACM Technical Symposium on Computer Science Education (SIGCSE)*, pages 2–8, 2020.

[TCNP25] Shahroz Tariq, Mohan Baruwal Chhetri, Surya Nepal, and Cécile Paris. Alert fatigue in security operations centres: Research challenges and opportunities. *ACM Computing Surveys*, 57(9):224:1–224:38, 2025.

[The24] The MITRE Corporation. D3FEND: A knowledge graph of cybersecurity countermeasures, 2024.

[TMZA25] Koen T. W. Teuwen, Tom Mulders, Emmanuele Zambon, and Luca Allodi. Ruling the unruly: Designing effective, low-noise network intrusion detection rules for security operations centers. In *ACM Asia Conference on Computer and Communications Security (AsiaCCS)*, pages 1428–1441. ACM, 2025.

[TPY+19] Kurt Thomas, Jennifer Pullman, Kevin Yeo, Ananth Raghunathan, Patrick Gage Kelley, Luca Invernizzi, Borbala Benko, Tadek Pietraszek, Sarvar Patel, Dan Boneh, and Elie Bursztein. Protecting accounts from credential stuffing with password breach alerting. In *28th USENIX Security Symposium*. USENIX Association, 2019.

[UHH+24] Rafael Uetz, Marco Herzog, Louis Hackländer, Simon Schwarz, and Martin Henze. You cannot escape me: Detecting evasions of SIEM rules in enterprise networks. In *33rd USENIX Security Symposium*. USENIX Association, 2024.

[vdHKG+25] Max van der Horst, Ricky Kho, Olga Gadyatskaya, Michel Mollema, Michel van Eeten, and Yury Zhauniarovich. High stakes, low certainty: Evaluating the efficacy of high-level indicators of compromise in ransomware attribution. In *34th USENIX Security Symposium*, pages 4819–4838. USENIX Association, 2025.

[VIR+24] Apurva Virkud, Muhammad Adil Inam, Andy Riddle, Jason Liu, Gang Wang, and Adam Bates. How does endpoint detection use the MITRE ATT&CK framework? In *33rd USENIX Security Symposium*. USENIX Association, 2024.

[vSWW+25] Christian van Sloun, Vincent Woeste, Konrad Wolsing, Jan Pennekamp, and Klaus Wehrle. Detecting ransomware despite I/O overhead: A practical multi-staged approach. In *Network and Distributed System Security Symposium (NDSS)*. The Internet Society, 2025.

[VVO+17] Jan Vykopal, Martin Vizváry, Radek Ošlejšek, Pavel Čeleda, and Daniel Tovarňák. Lessons learned from complex hands-on defence exercises in a cyber range. In *IEEE Frontiers in Education Conference (FIE)*, pages 1–8, 2017.

[WBWS23] Daniel W. Woods, Rainer Böhme, Josephine Wolff, and Daniel Schwarcz. Lessons lost: Incident response in the age of cyber insurance and breach attorneys. In *32nd USENIX Security Symposium*. USENIX Association, 2023.

[WSL+25] Lingzhi Wang, Xiangmin Shen, Weijian Li, Zhenyuan Li, R. Sekar, Han Liu, and Yan Chen. Incorporating gradients to rules: Towards lightweight, adaptive provenance-based intrusion detection. In *Network and Distributed System Security Symposium (NDSS)*. The Internet Society, 2025.

[XFL+22] Zhiqiang Xu, Pengcheng Fang, Changlin Liu, Xusheng Xiao, Yu Wen, and Dan Meng. DEPCOMM: Graph summarization on system audit logs for attack investigation. In *IEEE Symposium on Security and Privacy (SP)*. IEEE, 2022.

[YCW+24] Limin Yang, Zhi Chen, Chenkai Wang, Zhenning Zhang, Sushruth Booma, Phuong Cao, Constantin Adam, Alexander Withers, Zbigniew Kalbarczyk, Ravishankar K. Iyer, and Gang Wang. True attacks, attack attempts, or benign triggers? An empirical measurement of network alerts in a security operations center. In *33rd USENIX Security Symposium*. USENIX Association, 2024.

[YKG20] Muhammad Mudassar Yamin, Basel Katt, and Vasileios Gkioulos. Cyber ranges and security testbeds: Scenarios, functions, tools and architecture. *Computers & Security*, 88:101636, 2020.

[YXX+23] Fan Yang, Jiacen Xu, Chunlin Xiong, Zhou Li, and Kehuan Zhang. ProGrapher: An anomaly detection system based on provenance graph embedding. In *32nd USENIX Security Symposium*. USENIX Association, 2023.

[ZCC+21] Jun Zeng, Zheng Leong Chua, Yinfang Chen, Kaihang Ji, Zhenkai Liang, and Jian Mao. WATSON: Abstracting behaviors from audit logs via aggregation of contextual semantics. In *Network and Distributed System Security Symposium (NDSS)*. The Internet Society, 2021.

[ZGY+25] Bo Zhang, Yansong Gao, Changlong Yu, Boyu Kuang, Zhi Zhang, Hyoungshick Kim, and Anmin Fu. TAPAS: An efficient online APT detection with task-guided process provenance graph segmentation and analysis. In *34th USENIX Security Symposium*. USENIX Association, 2025.

[ZZW+25] Lingbo Zhao, Yuhui Zhang, Zhilu Wang, Fengkai Yuan, and Rui Hou. ERW-Radar: An adaptive detection system against evasive ransomware by contextual behavior detection and fine-grained content analysis. In *Network and Distributed System Security Symposium (NDSS)*. The Internet Society, 2025.